🌐 Module 04: Social Engineering Penetration Testing Methodology

```
# Exercise 1: Sniff credentials using the Social-Engineer Toolkit (SET)
```

Scenario

The main objective of social engineering penetration testing is to check the loyalty of employees in the organization, their awareness regarding phishing attacks, their ability to comply with security policies, and the application of their security training. Penetration testers may employ various techniques involving the use of phones, and physical, and internet-based engagements with the employees, to identify those who fall prey to these techniques. To perform social engineering pen testing, testers must gather all the information of the victim and use this information to gather sensitive organization data.

As a penetration tester, you must know how to crack cloned malicious login pages, mask the cloned webpage URLs, and entice the employees in an organization to click them.

The Social-Engineer Toolkit (SET) is an open-source Python-driven tool aimed at penetration testing via social engineering. SET is useful to attackers because it is freely available and can be used to carry out a range of attacks. For example, it allows attackers to compose phishing email messages, attach malicious files, and send them to many people using spear phishing. Additionally, SET's multi-attack method allows Java applets, the Metasploit browser, and Credential Harvester/Tabnabbing to be used simultaneously. SET categorizes attacks based on the attack vector used, such as email, web, and USB.

While SET can be used to carry out a variety of attacks, it is also an essential tool for penetration testers to identify vulnerabilities. For this reason, SET is the industry standard for social engineering penetration tests and is widely supported within the security community.

As an ethical hacker, penetration tester, or security administrator, you should be familiar with SET and be able to use it to perform various tests for network vulnerabilities.

Here, we will sniff user credentials using the SET.

Objective

The objective of this lab is to help students learn how to sniff user credentials using SET:
- Sniffing User Credentials using SET's Site Cloner
- Sniffing user credentials using SET's QRCode Generator Attack Vector

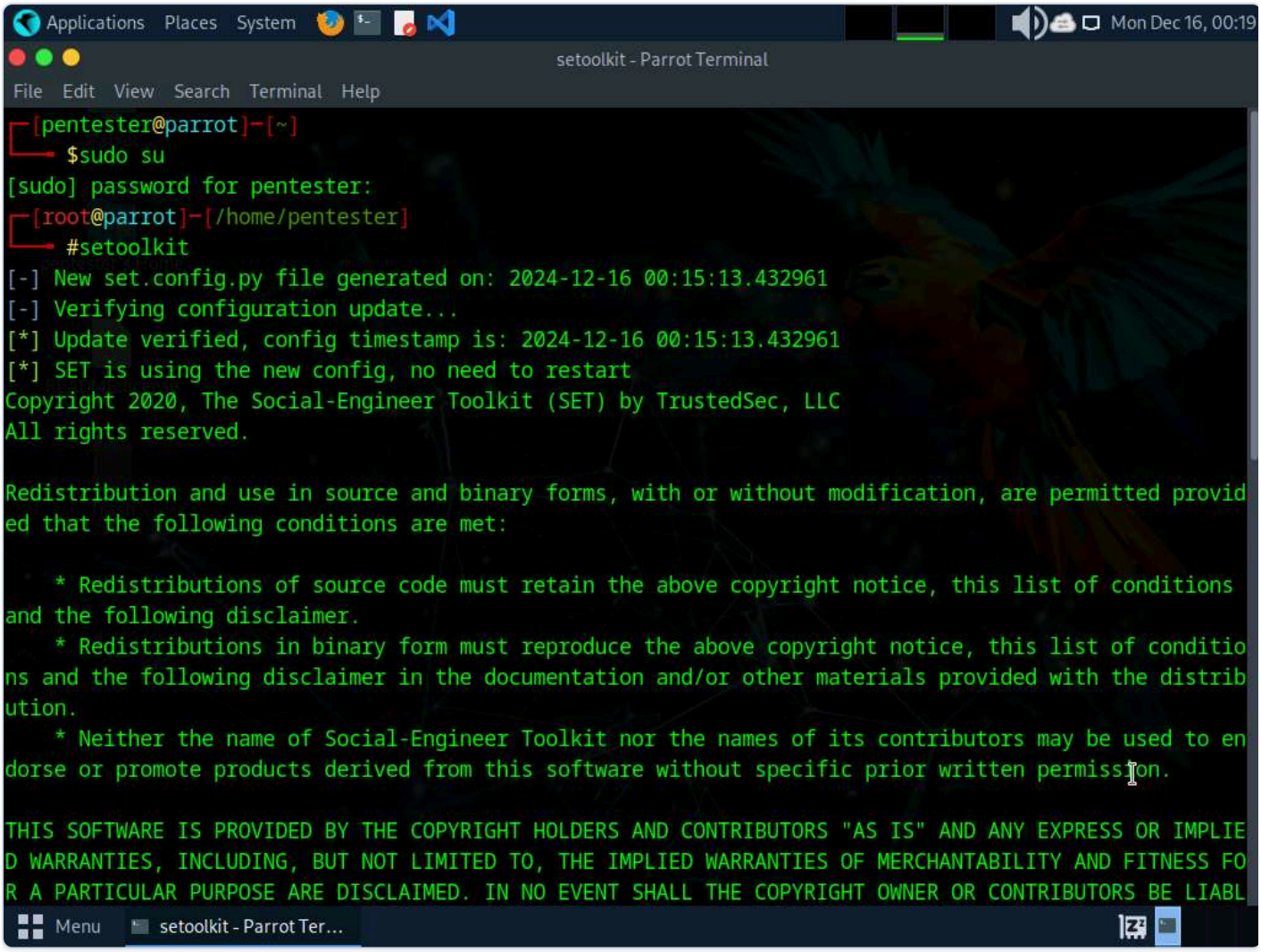
> **NOTE:** All lab manuals are accessible in the **Lab Manuals** folder located on the Desktop of the machines. Please refer to the respective lab manual if you need to copy and paste any commands or code during the lab sessions.

Task 1: Sniffing User Credentials using SET's Site Cloner

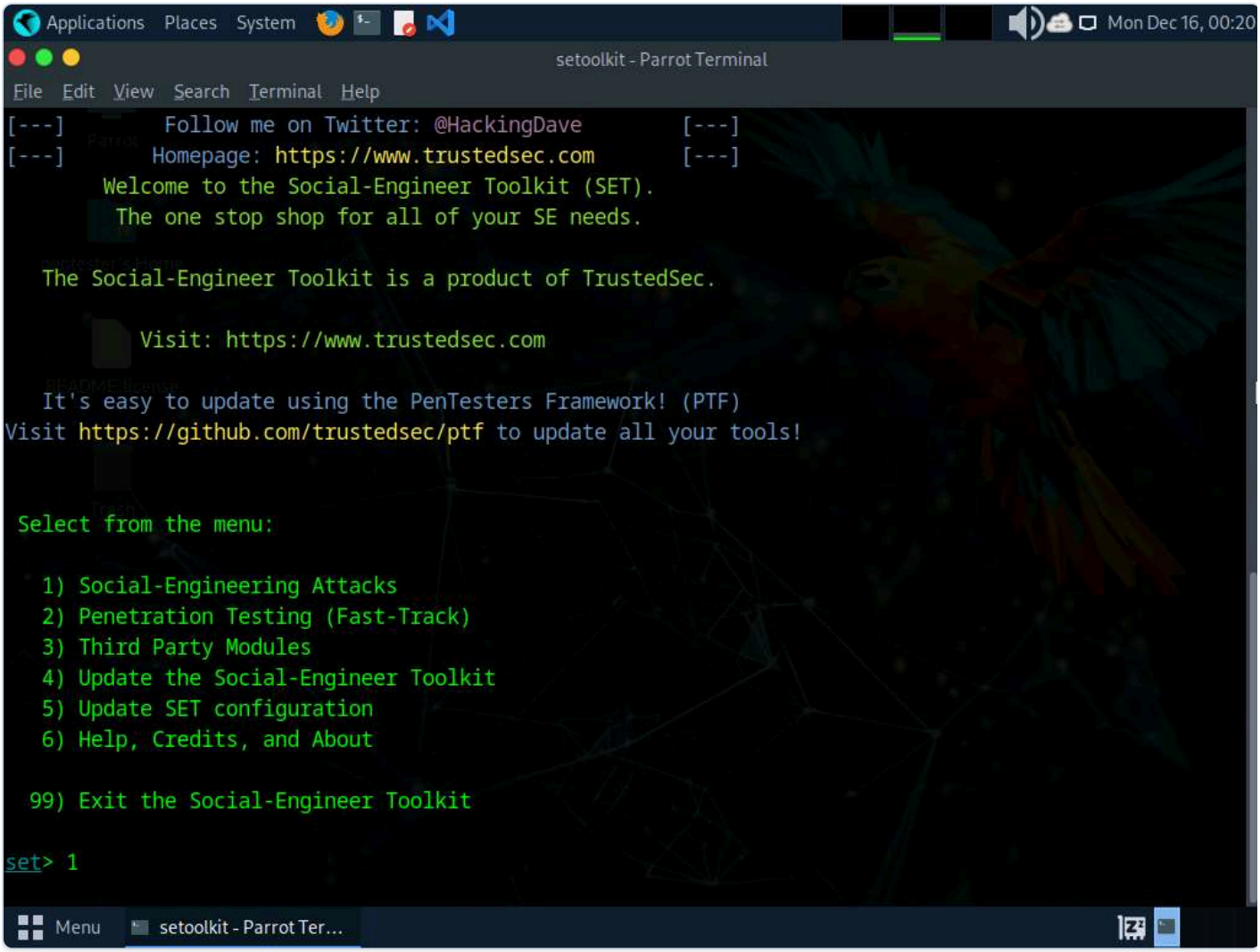
In this task, we will clone a target website and host it on the Parrot Security machine using SET's Site Cloner feature to capture victim credentials.

Lab Tasks

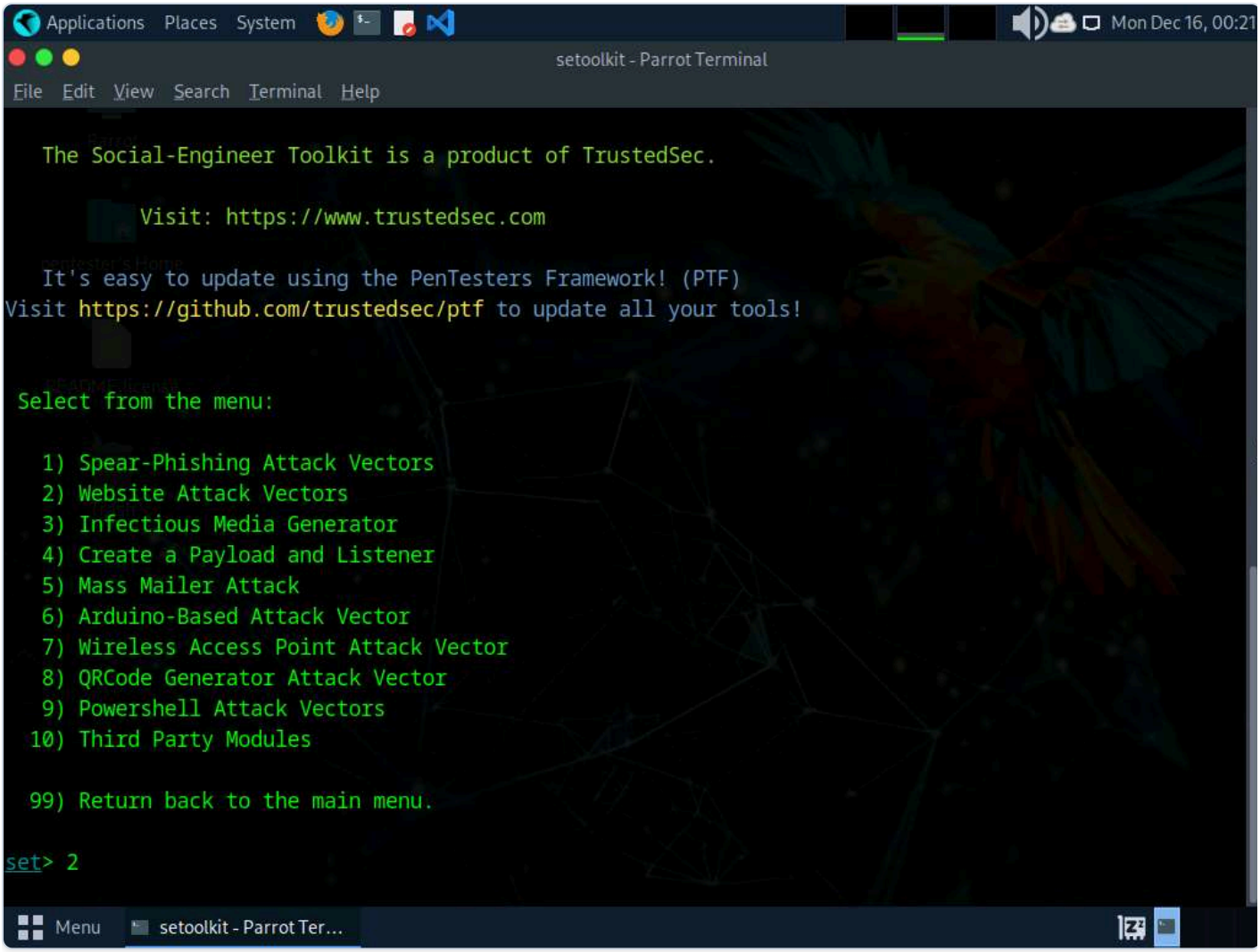
1. Click on **Parrot Security** to switch to the Parrot Security machine. Login using **pentester** / **toor**.
2. *(If a Question pop-up window appears asking you to update the machine, click No to close the window.)*
3. Open a Terminal window and execute **sudo su** to run the programs as a root user (When prompted, enter the password **toor**).
4. Run **setoolkit** to launch Social-Engineer Toolkit.
5. *(If a Do you agree to the terms of service [y/n] question appears, enter y and press Enter.)*



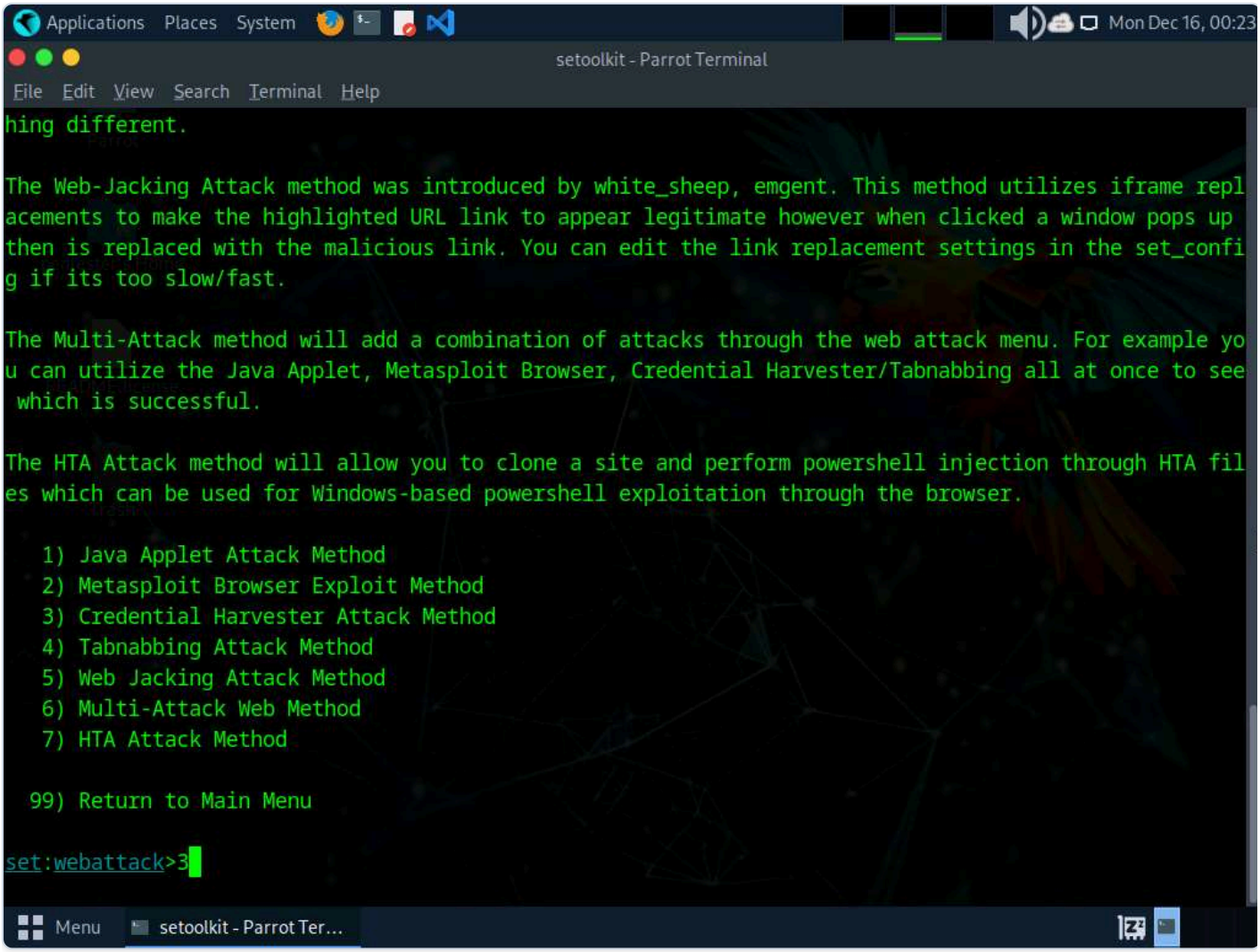
1. The SET menu appears as shown in the screenshot below. Type **1** and press Enter to choose **Social-Engineering Attacks**.



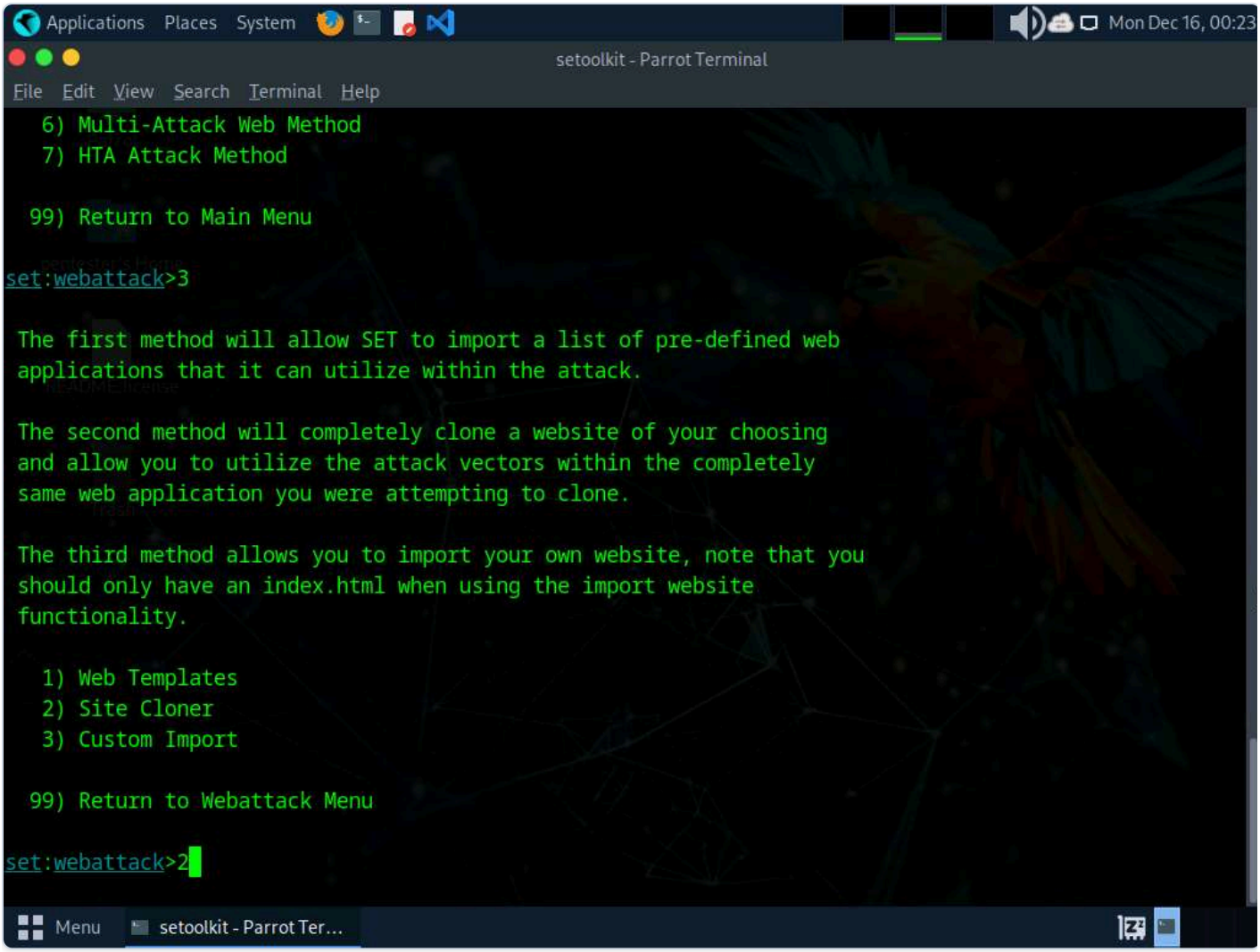
1. A list of options for Social-Engineering Attacks appears; type **2** and press Enter to choose **Website Attack Vectors**.



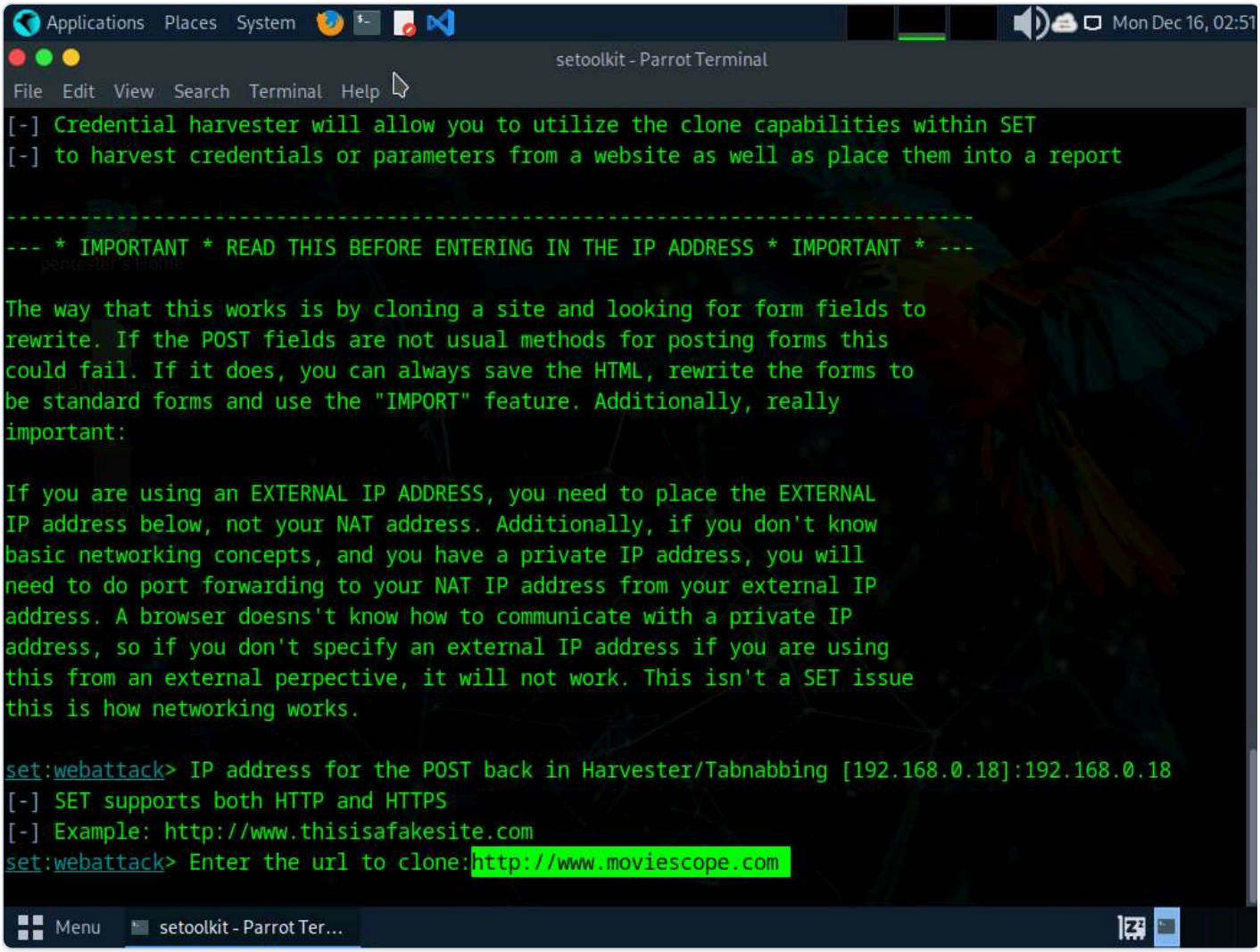
1. A list of options in Website Attack Vectors appears; type **3** and press Enter to choose **Credential Harvester Attack Method**.



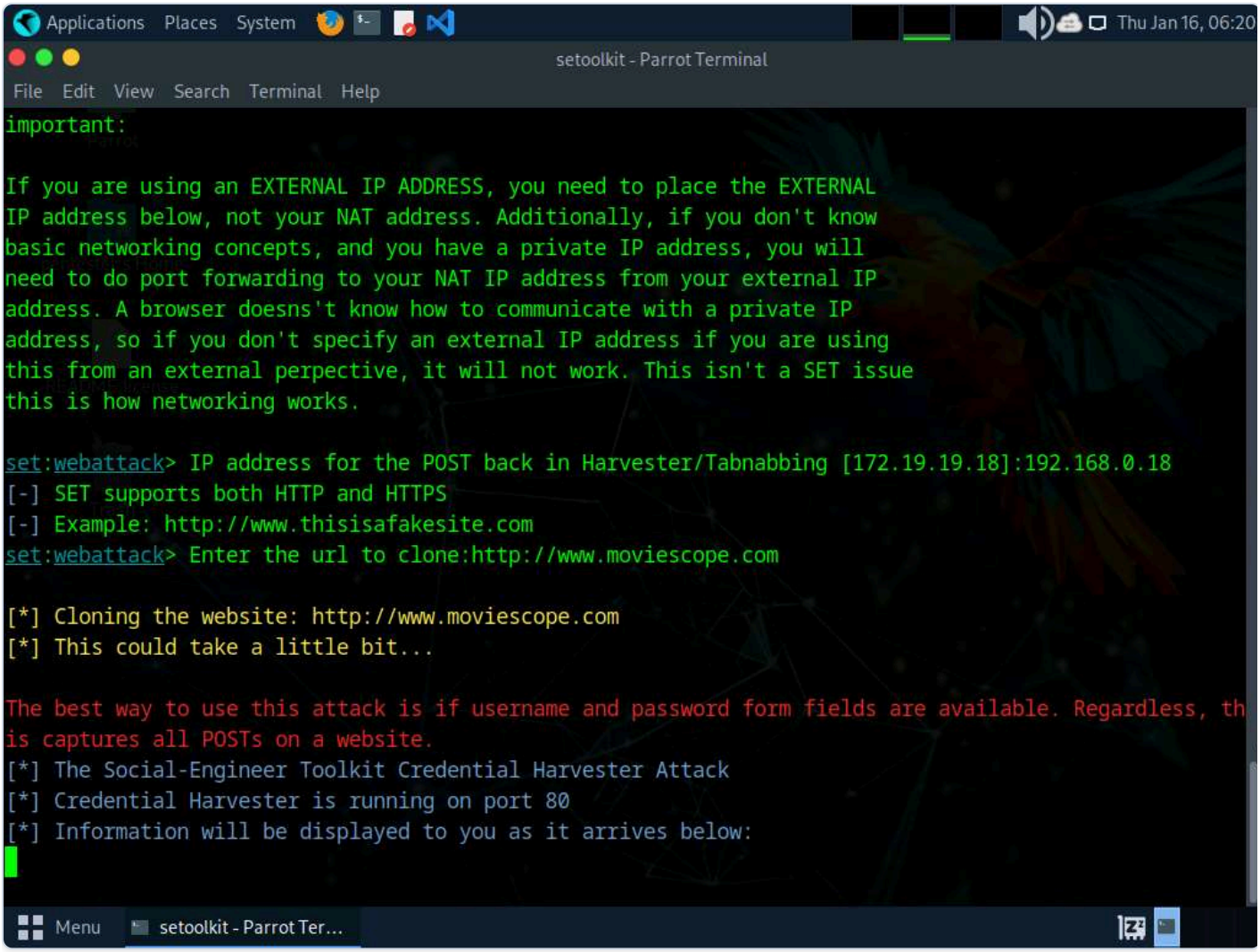
1. Type **2** and press Enter to choose **Site Cloner** from the menu.



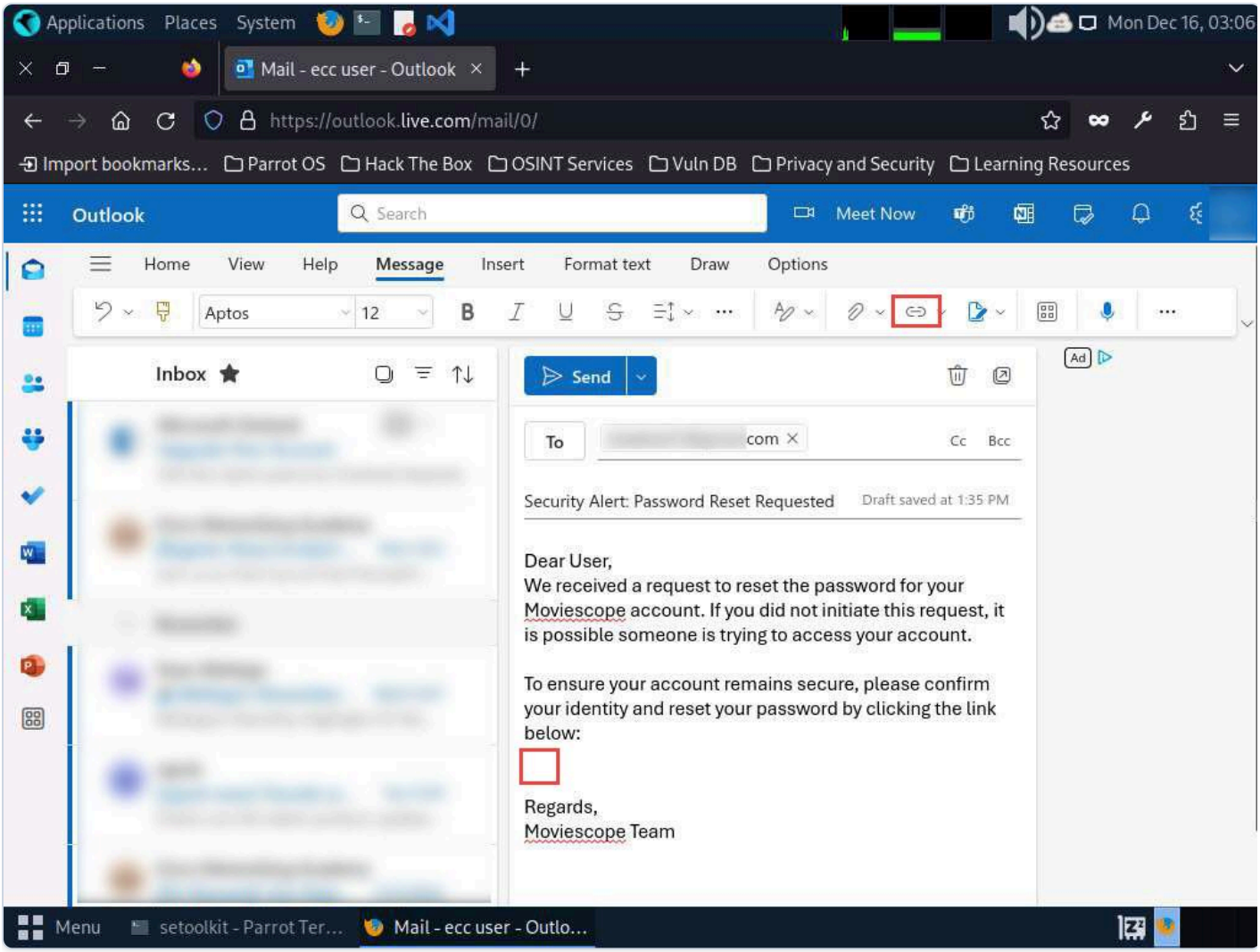
1. Type the IP address of the local machine (**192.168.0.18**) in the prompt for *"IP address for the POST back in Harvester/Tabnabbing"* and press Enter.
2. *(In this case, we are targeting the Parrot Security machine (IP address: **192.168.0.18**).)*
3. Now, you will be prompted to enter the URL to clone. Type the desired URL in the Enter the url to clone field and press Enter. In this task, we will clone the URL **http://www.moviescope.com**.
4. *(You can clone any URL of your choice.)*



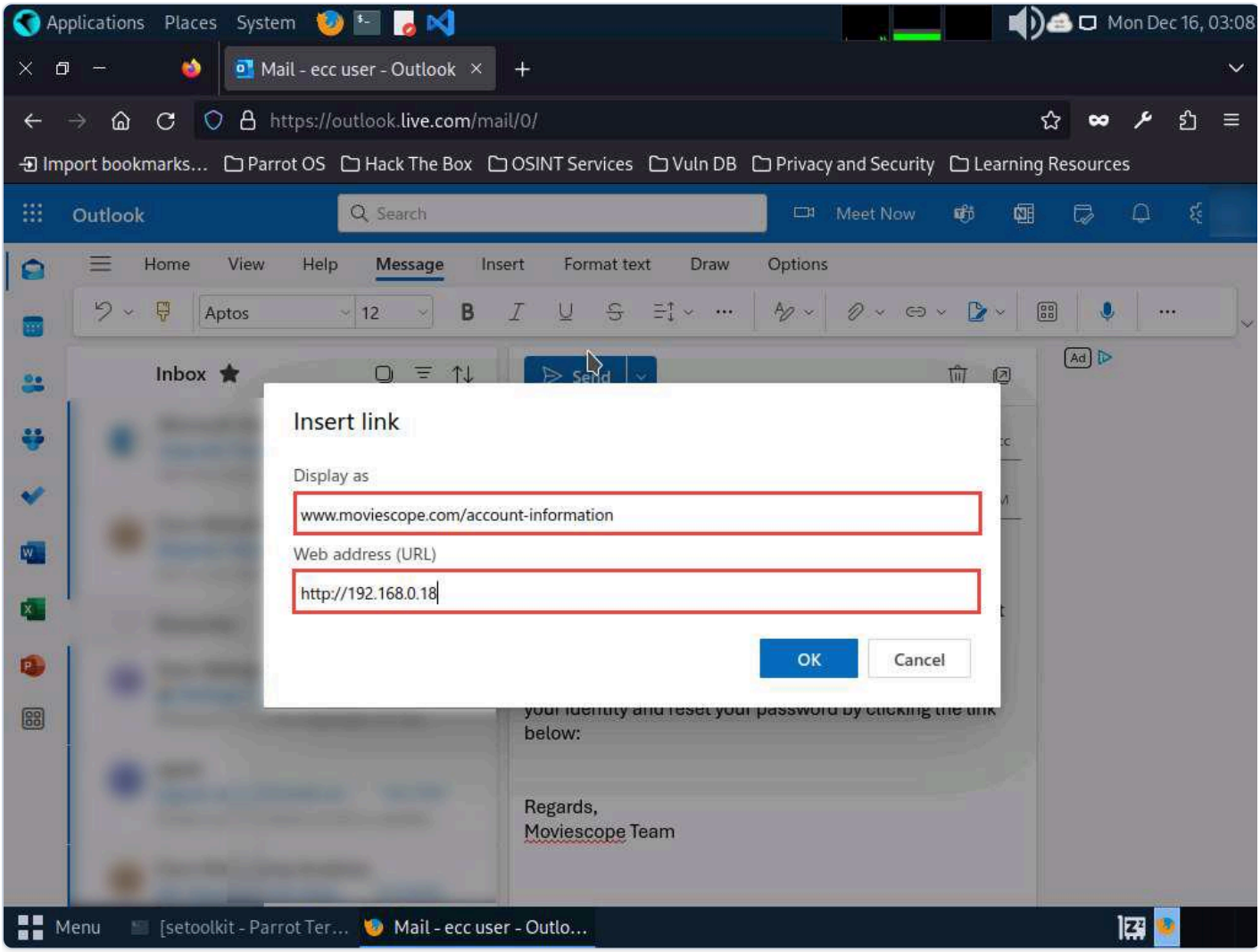
1. After cloning is completed, the credential harvester initiates as shown in the screenshot.



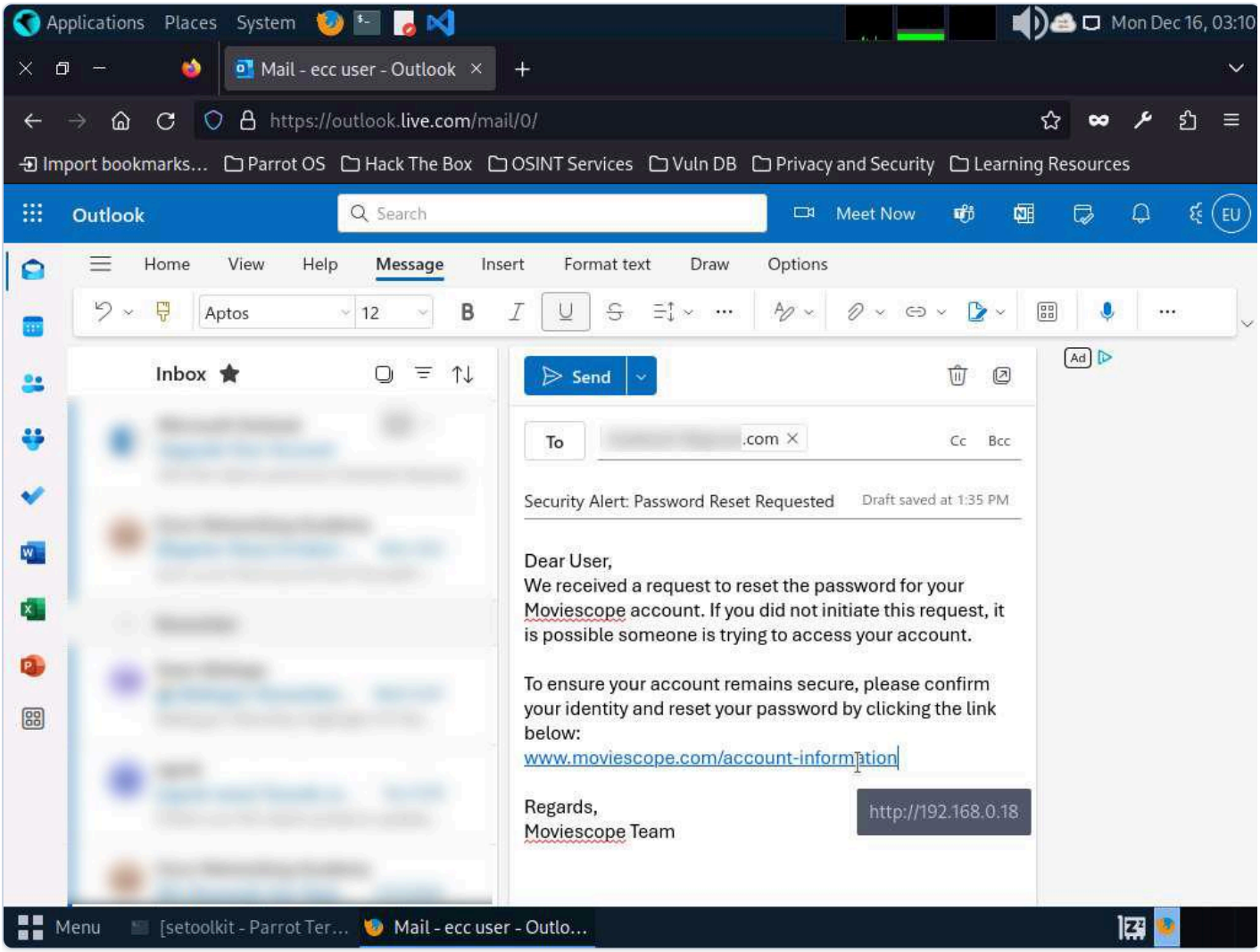
1. Having successfully cloned a website, you must now send the IP address of your Parrot Security machine to a victim and try to trick them into clicking on the link.
2. Click the Firefox icon from the top section of the Desktop to launch a web browser window and open your email account (in this example, we will be using Mozilla Firefox and Outlook). Log in and compose an email.
    - *(You can log in to any email client of your interest.)*
3. After logging into your email account, click the **New Mail** button in the left pane and compose a fake but enticing email to lure a user into opening the email and clicking on a malicious link.
4. Position the cursor just above Regards to place the fake URL, then click the **Insert link** icon.



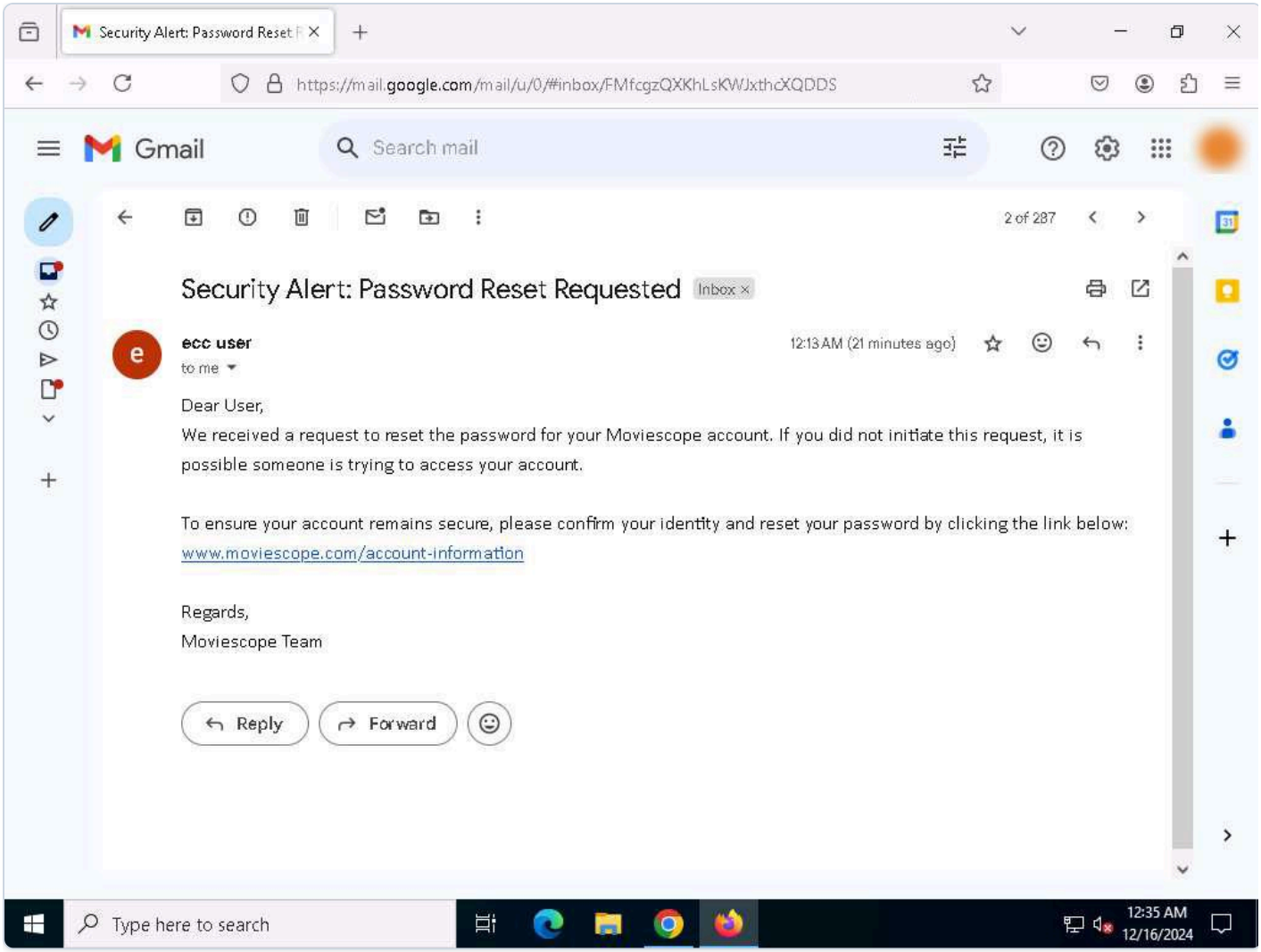
1. In the Insert link window, first enter the fake URL in the Display as field (**www.moviescope.com/account-information**). Next, input the actual address of your cloned site in the Web address (URL) field (**http://192.168.0.18**) and click **OK**.



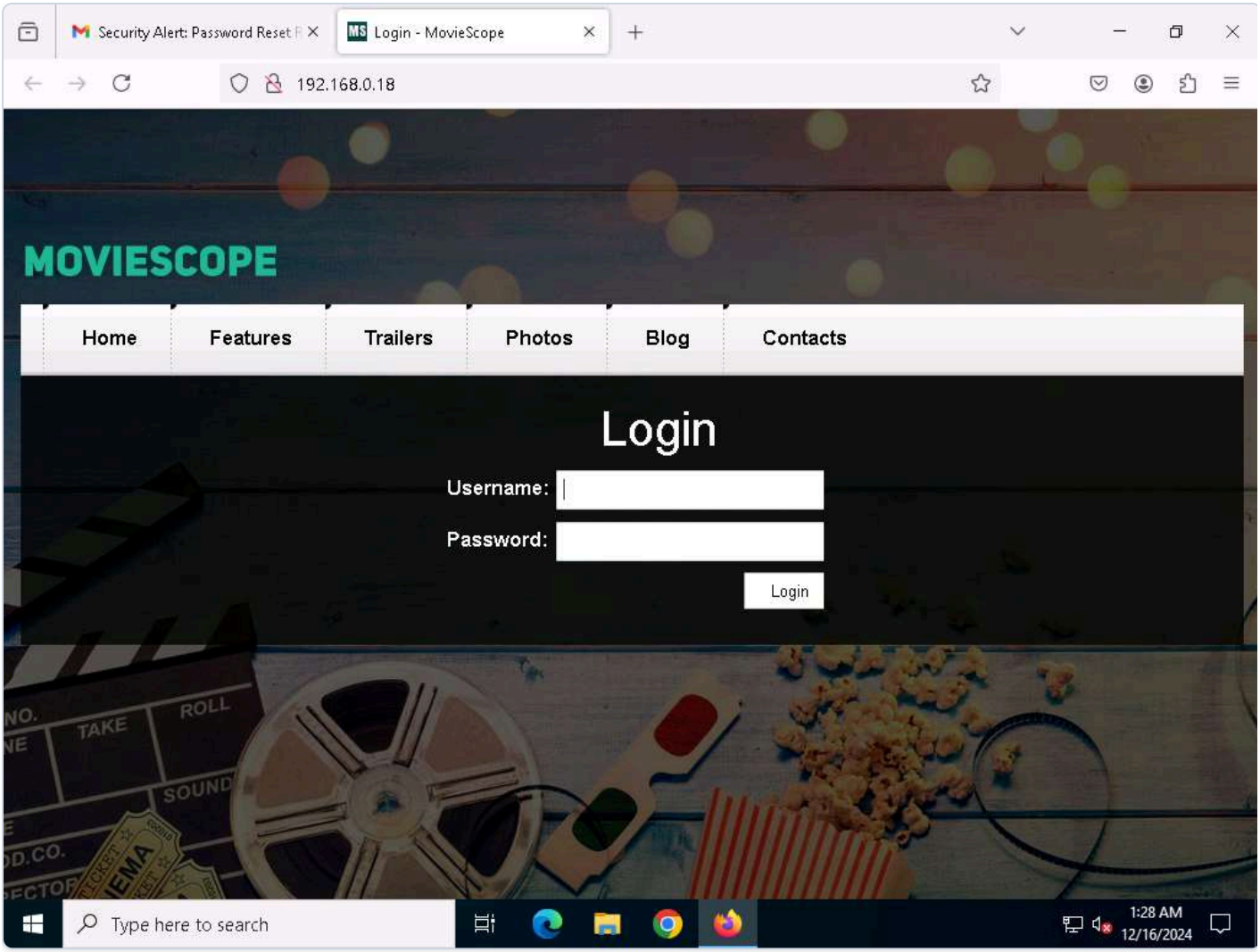
1. The fake URL should appear in the message body. Verify that the fake URL is linked to the correct cloned site: in Outlook, hover over the link; the actual URL will be displayed. Once verified, send the email to the intended user.

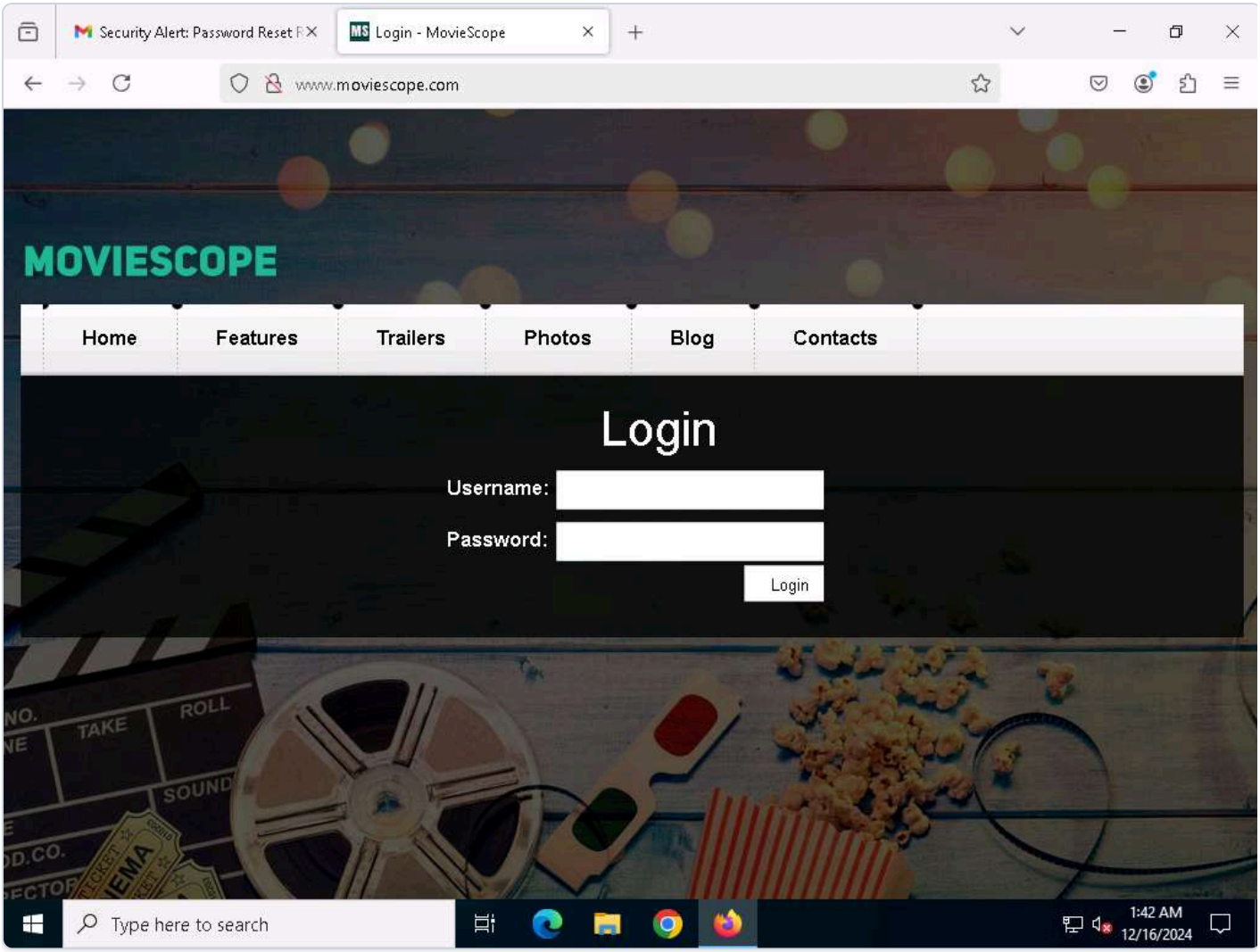


1. Click **Windows Server 2022** to switch to the Windows machine and log in using **Admin** / **Pa$$w0rd**.
2. Open any web browser (here, we are using Google Chrome), and sign in to the email account to which you sent the phishing mail as an attacker. Open the email you sent previously and click to open the malicious link.

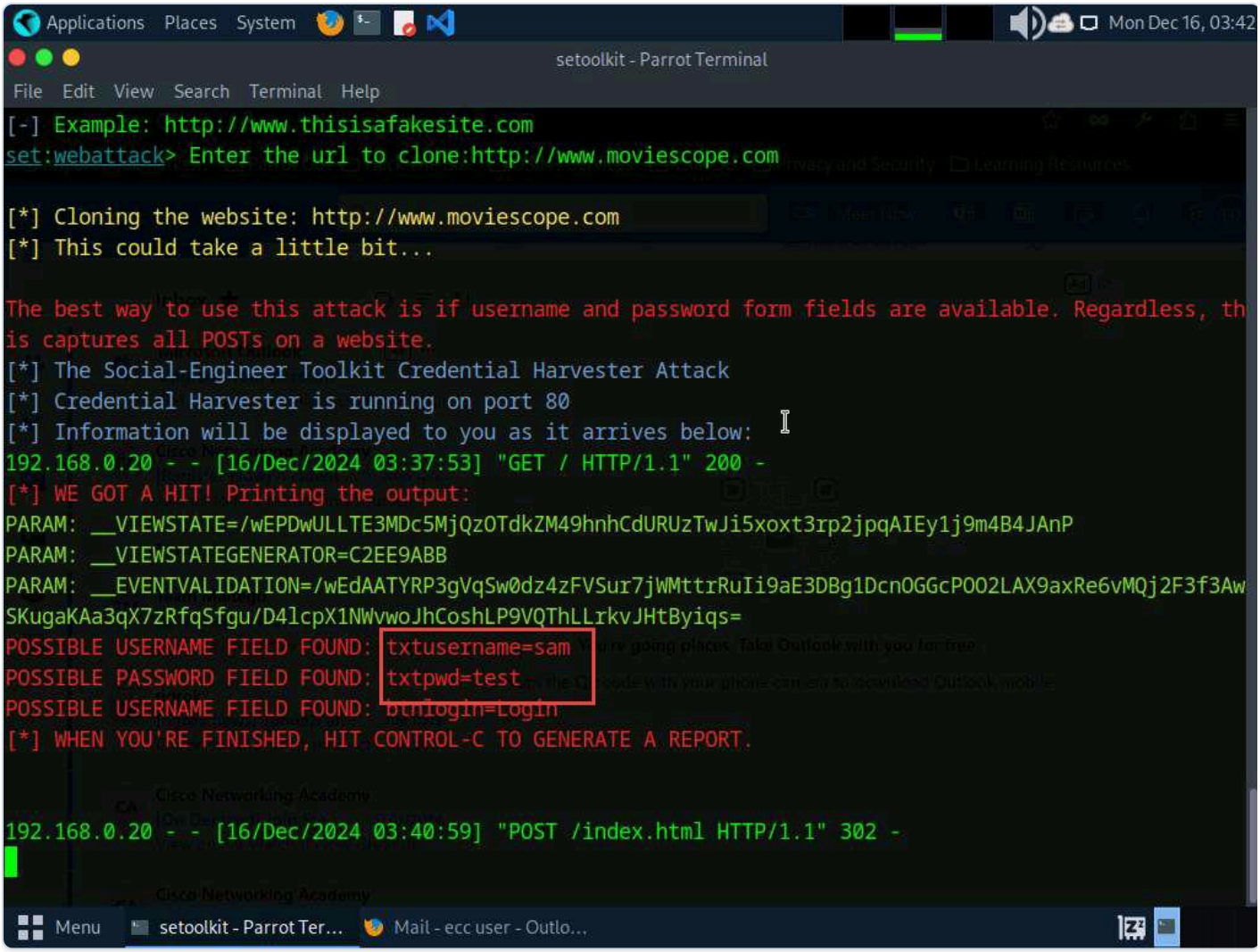


1. When the victim (you in this case) clicks the URL, a new tab opens, and the victim sees a replica of **www.moviescope.com**.
2. The victim will be prompted to enter the username and password into the form fields, which appear as they do on the genuine website. When the victim enters the credentials and clicks Login, they will be redirected to the legitimate MovieScope login page. Note the different URLs in the browser address bar for the cloned and legitimate sites.

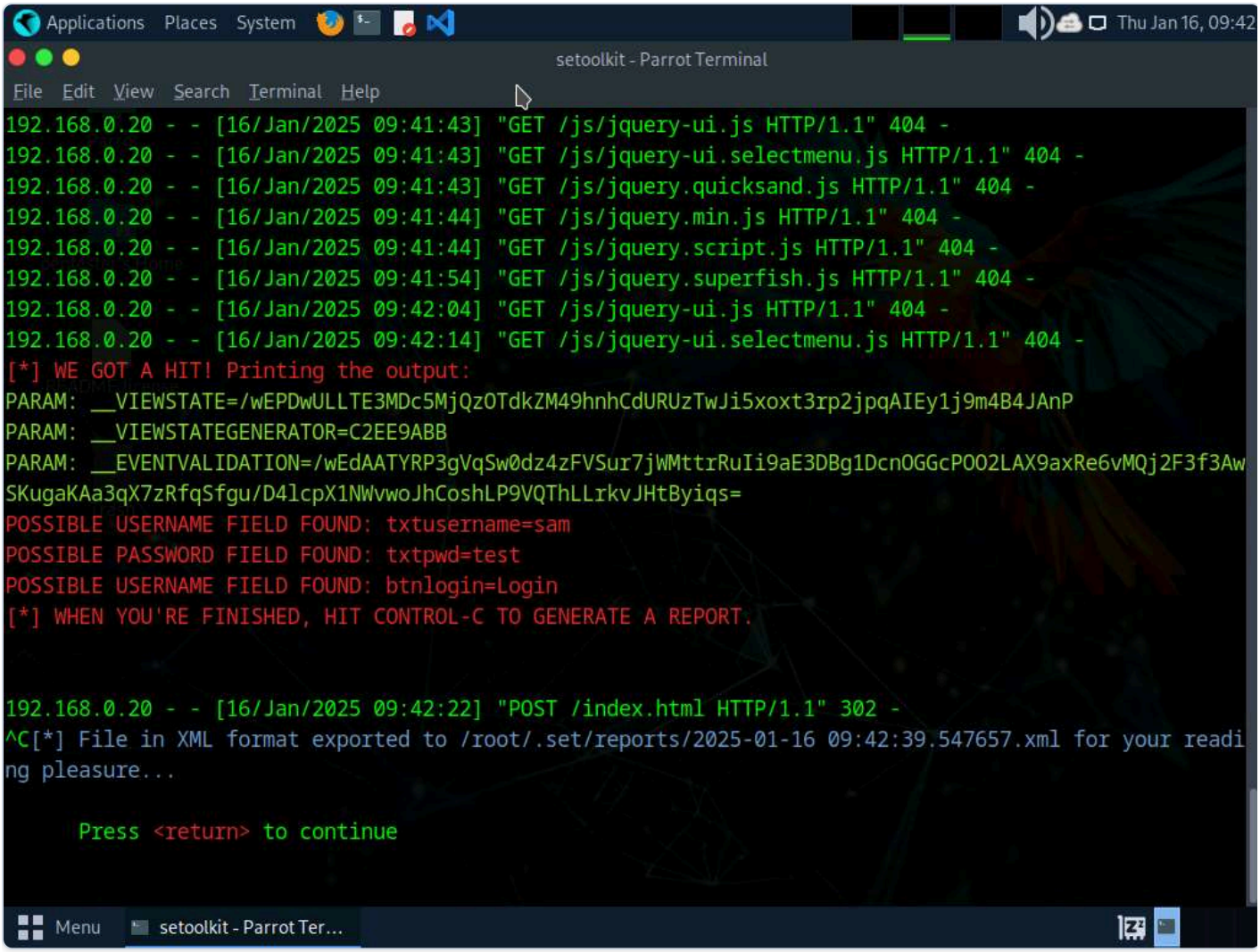

Security Alert: Password Reset
Login - MovieScope
192.168.0.18
MOVIESCOPE
Home
Features
Trailers
Photos
Blog
Contacts
Login
Username:
Password:
Login
Type here to search
1:28 AM
12/16/2024



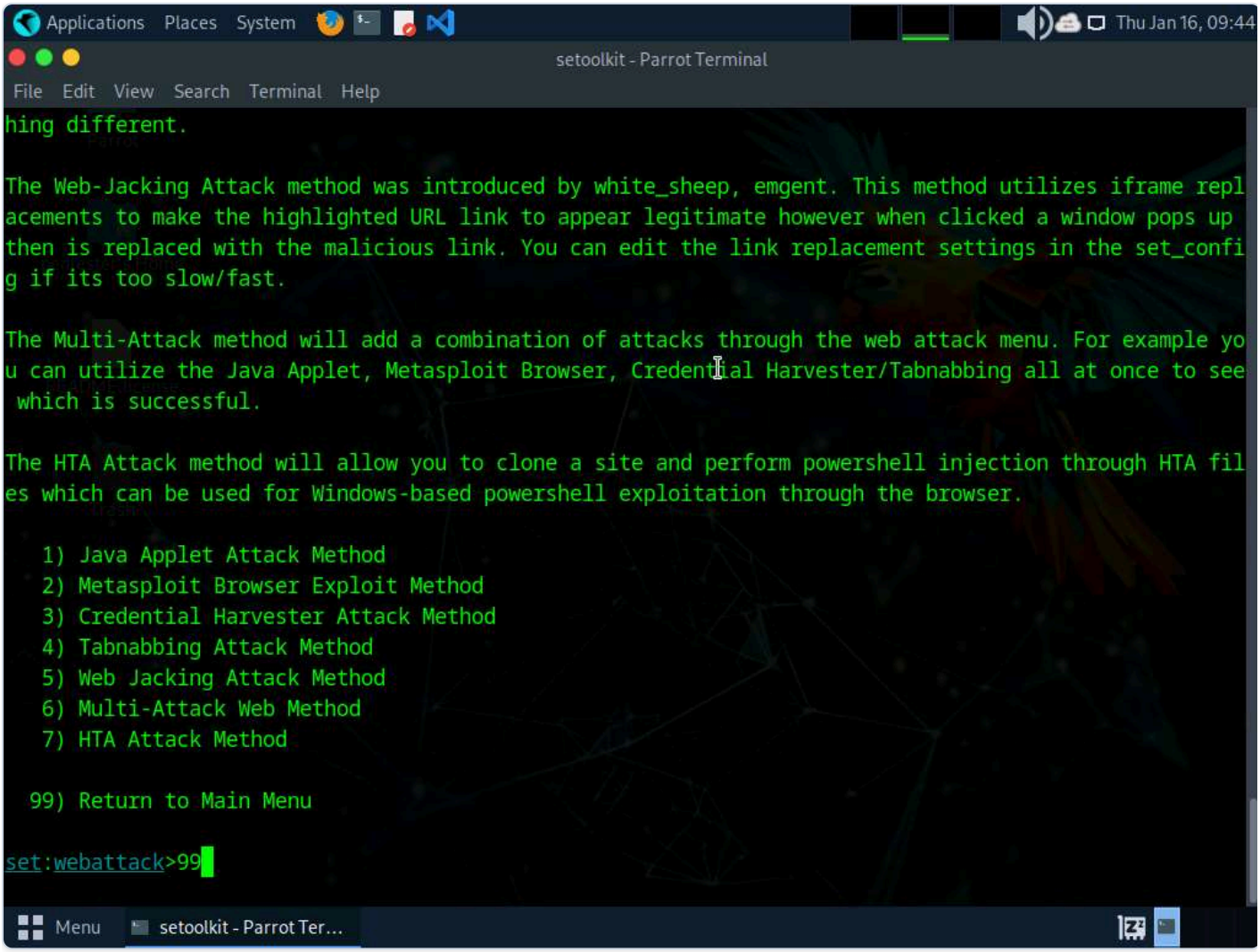
1. Now, click on **Parrot Security** to switch back to the Parrot Security machine and switch to the terminal window. Soon after the victim types in the Username and Password and clicks Login, SET records the credentials. The attacker can then use them to gain unauthorized access to the victim's account.
2. Scroll down to find the Username and Password displayed in plain text, as shown in the screenshot.

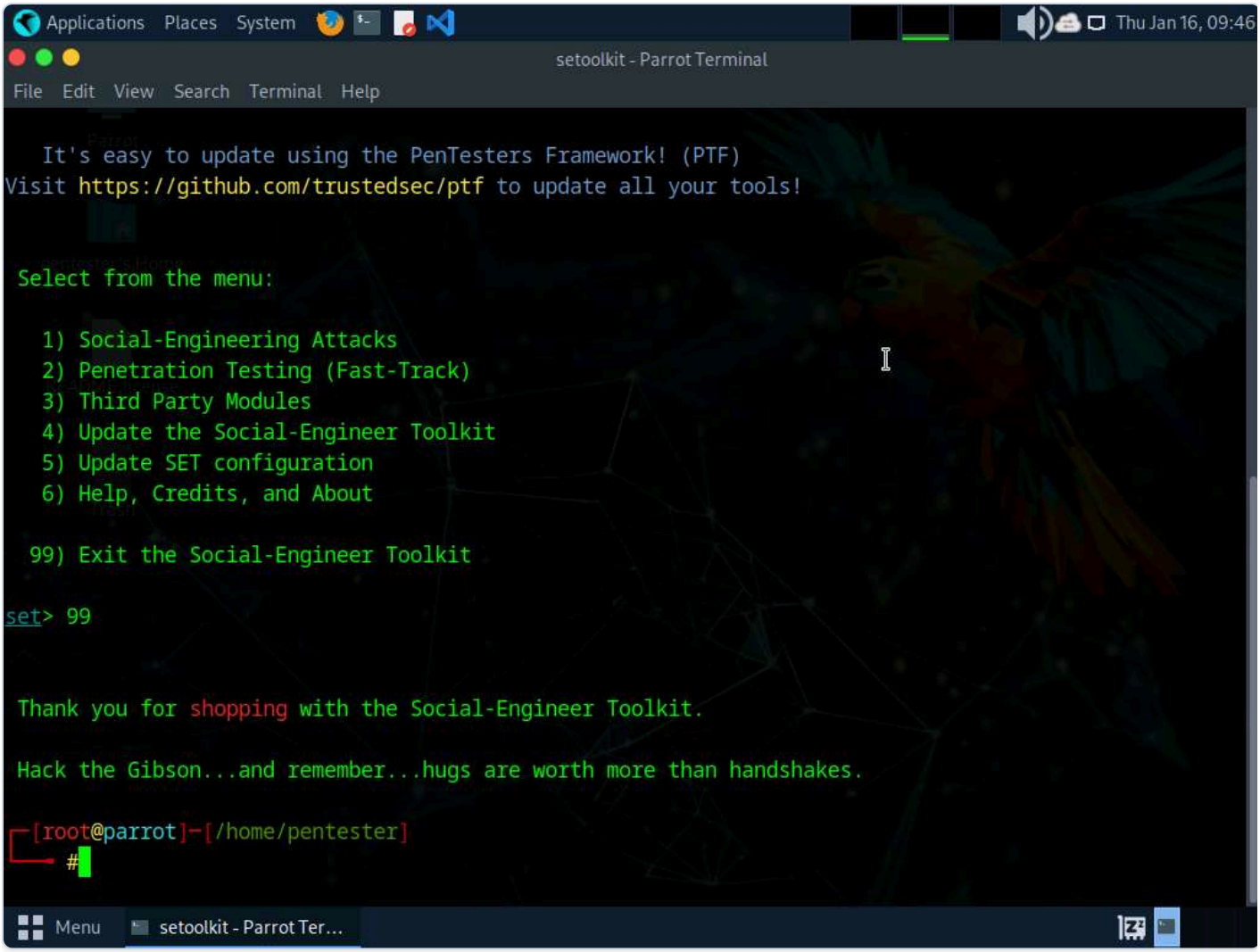


1. Now, hit **Ctrl+C** and then, press Enter to return to the previous menu.



1. Keep hitting **Ctrl+C** or keep entering **99** in the SET terminal until you come out of the SET terminal.


Applications Places System
Thu Jan 16, 09:44
setoolkit - Parrot Terminal
File Edit View Search Terminal Help
hing different.
The Web-Jacking Attack method was introduced by white_sheep, emgent. This method utilizes iframe repl
acements to make the highlighted URL link to appear legitimate however when clicked a window pops up
then is replaced with the malicious link. You can edit the link replacement settings in the set_confi
g if its too slow/fast.
The Multi-Attack method will add a combination of attacks through the web attack menu. For example yo
u can utilize the Java Applet, Metasploit Browser, Credential Harvester/Tabnabbing all at once to see
which is successful.
The HTA Attack method will allow you to clone a site and perform powershell injection through HTA fil
es which can be used for Windows-based powershell exploitation through the browser.
1) Java Applet Attack Method
2) Metasploit Browser Exploit Method
3) Credential Harvester Attack Method
4) Tabnabbing Attack Method
5) Web Jacking Attack Method
6) Multi-Attack Web Method
7) HTA Attack Method
99) Return to Main Menu
set:webattack>99
Menu
setoolkit - Parrot Ter...



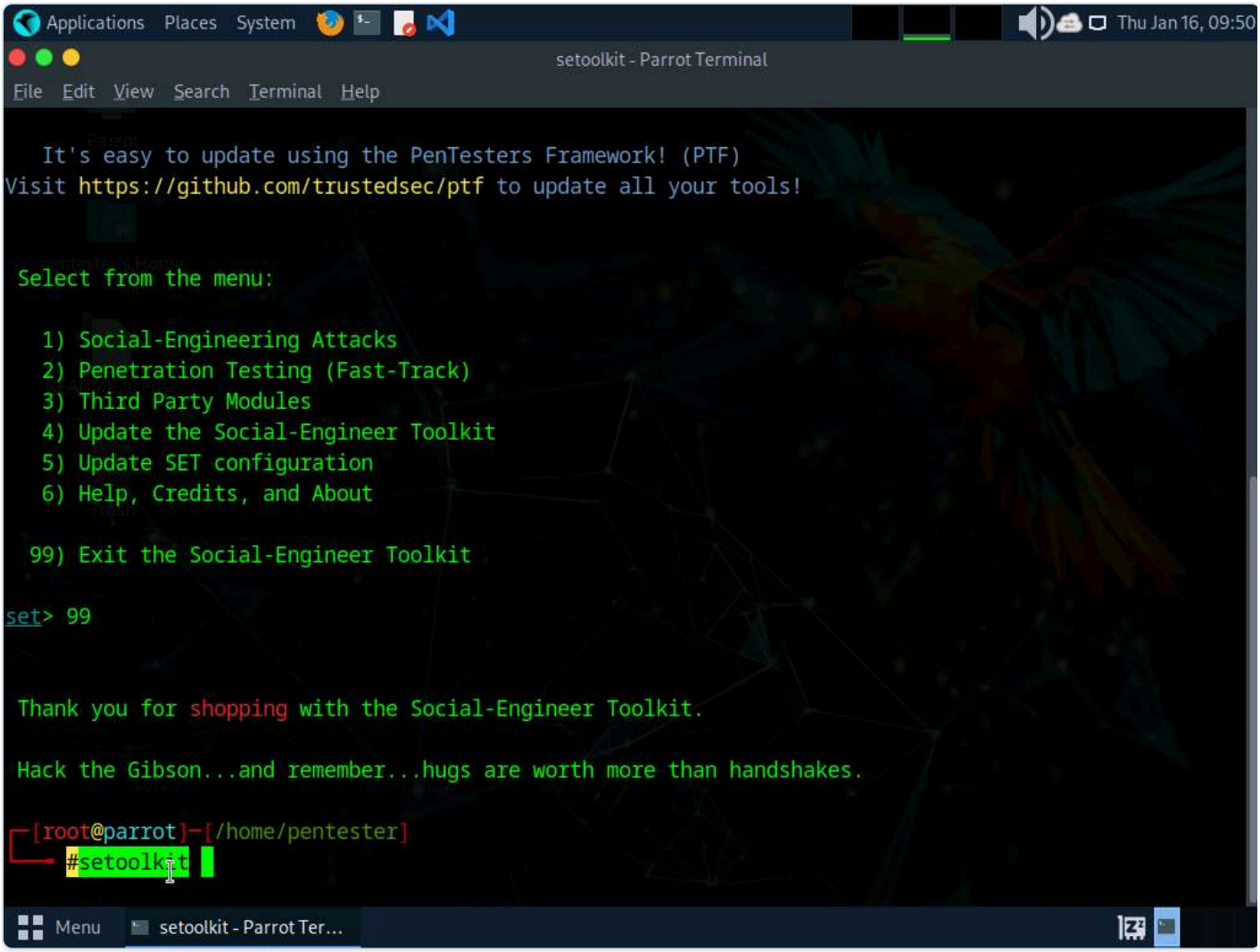
(Keep all current windows open as the next section builds on the content of this section.)

Task 2: Sniffing User Credentials using SET's QRCode Generator Attack Vector

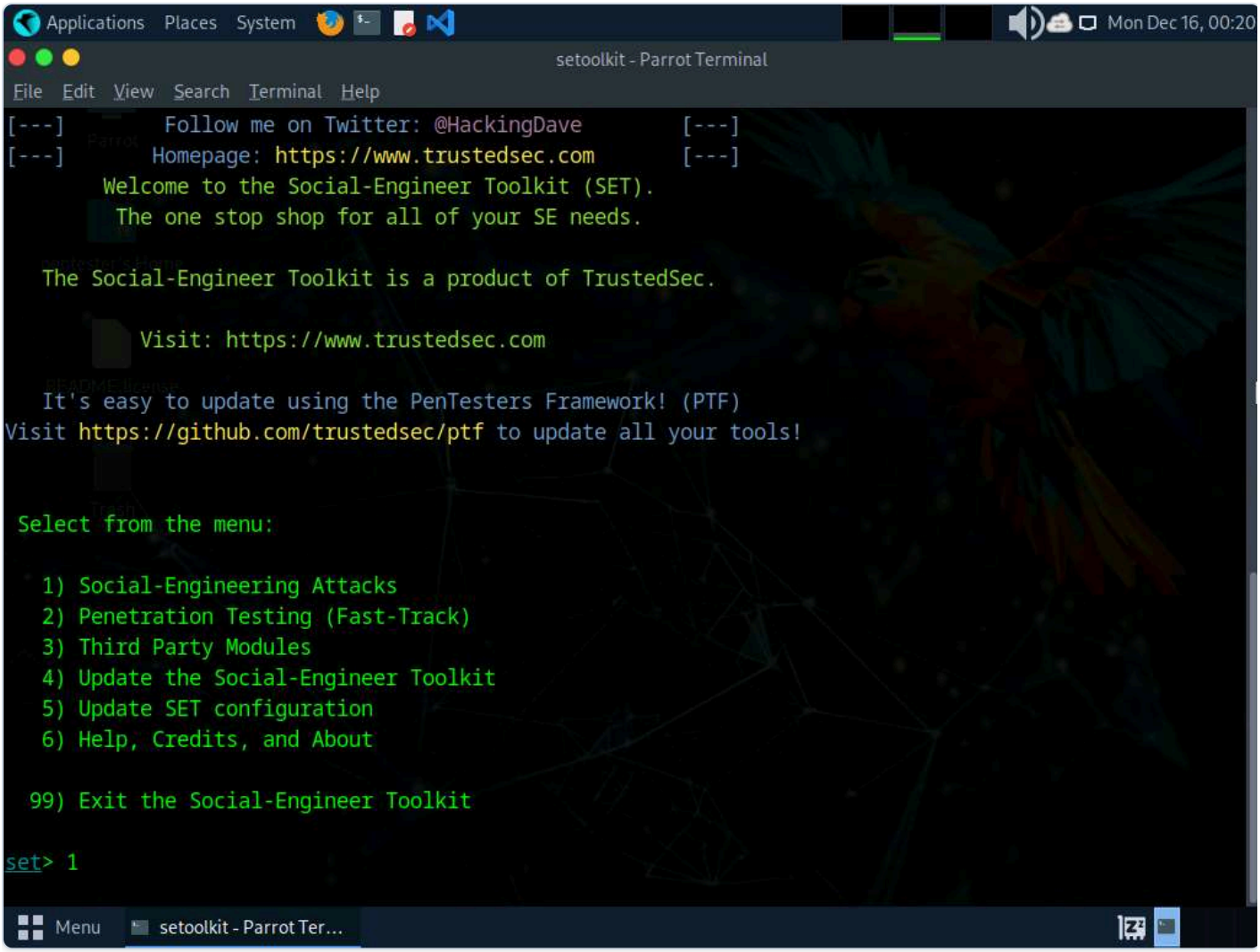
In this section of the lab, we are going to demonstrate steps to propagate the malicious cloned page via QR code. We will be using SET's QRCode Generator Attack Vector in conjunction with the Site Cloner utility in SET to create a QR code that points to the IP address of the Parrot Security machine (which is hosting the cloned page).

Lab Tasks

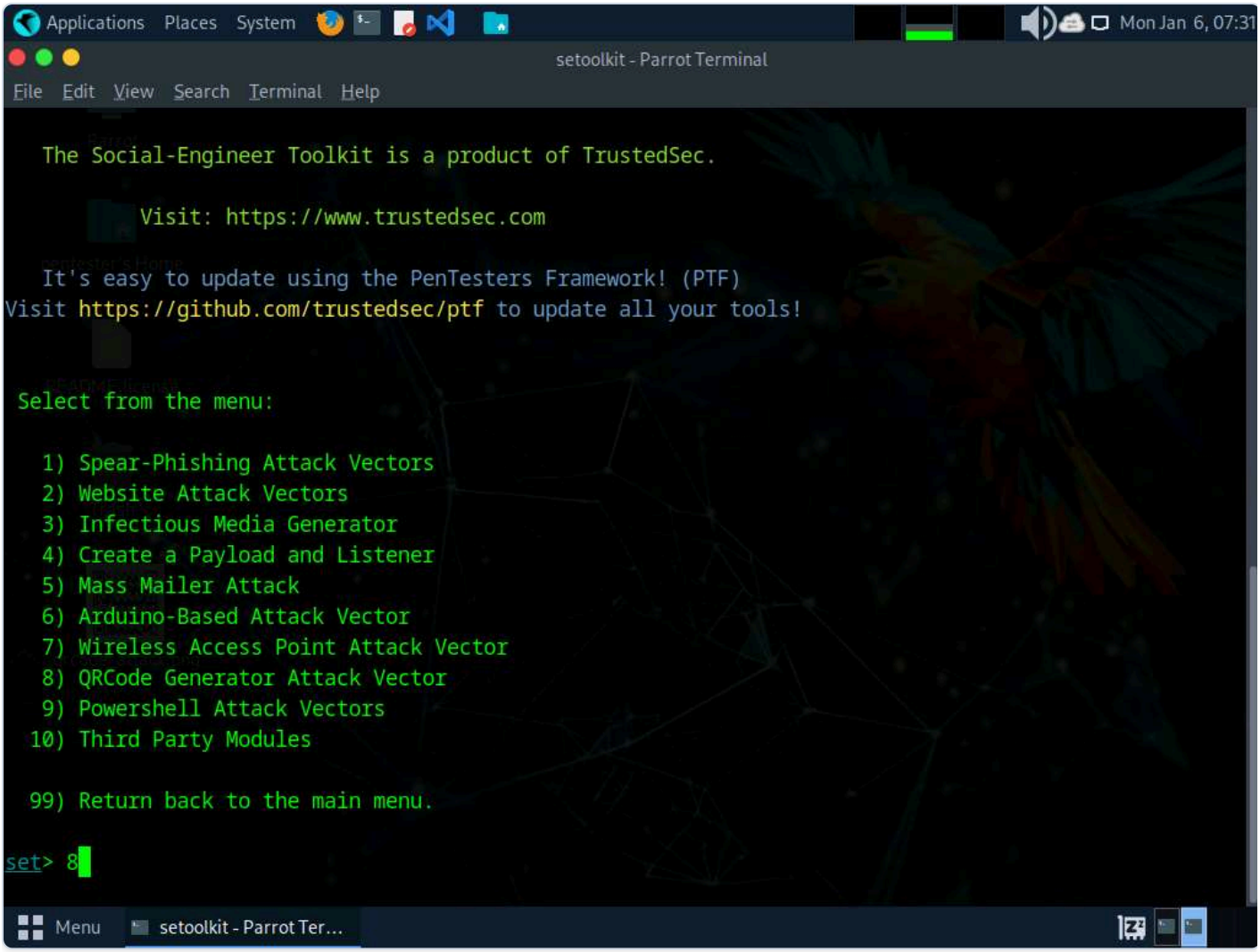
1. If you have the terminal open from the previous section, execute the command **setoolkit** in it to launch Social-Engineer Toolkit. If the terminal is not open, open a new one and execute the **sudo su** command to run the programs as a root user (When prompted, enter the password **toor**).
2. *(If a Do you agree to the terms of service [y/n] question appears, enter y and press Enter.)*



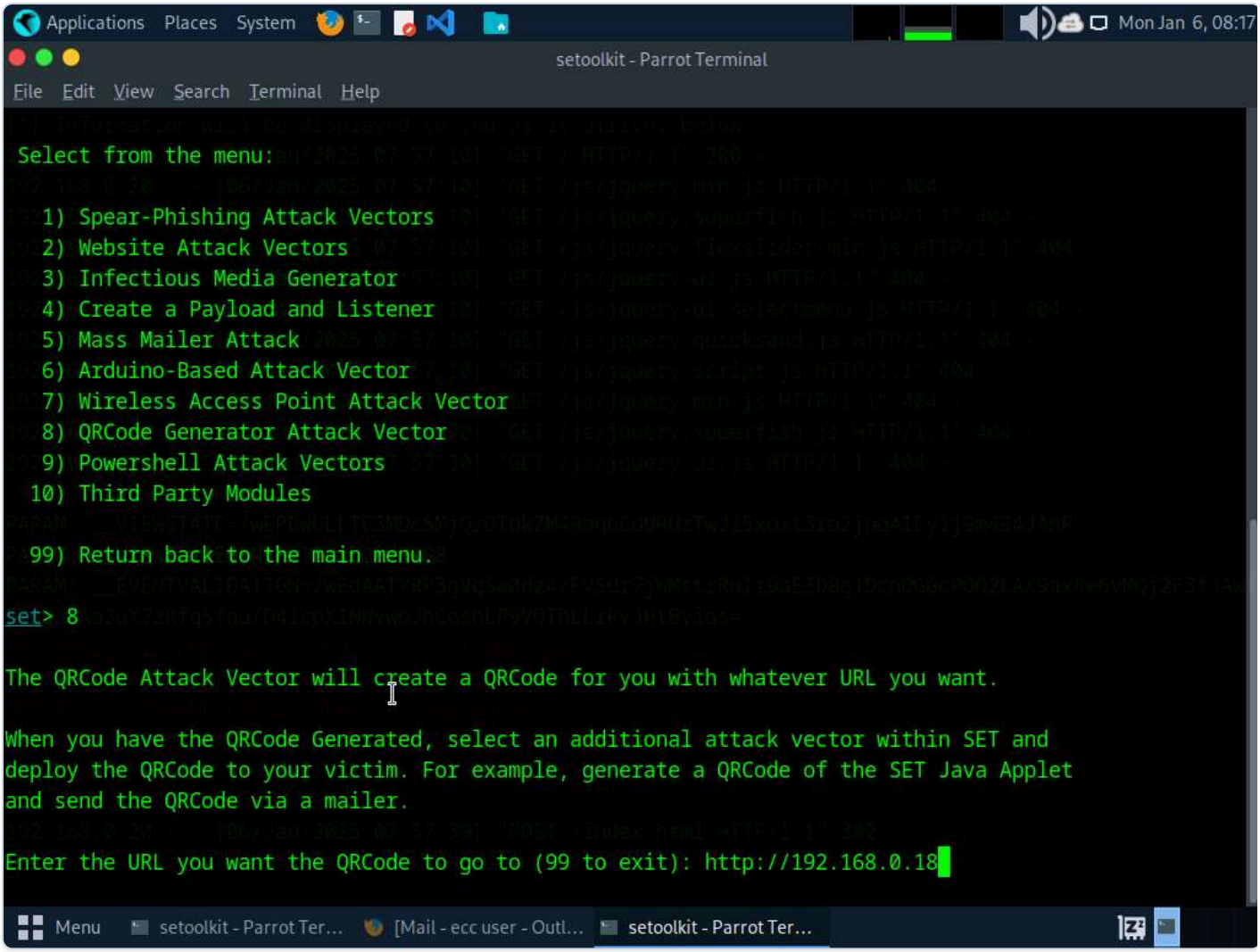
1. The SET menu appears as shown in the screenshot. Type **1** and press Enter to choose **Social-Engineering Attacks**.



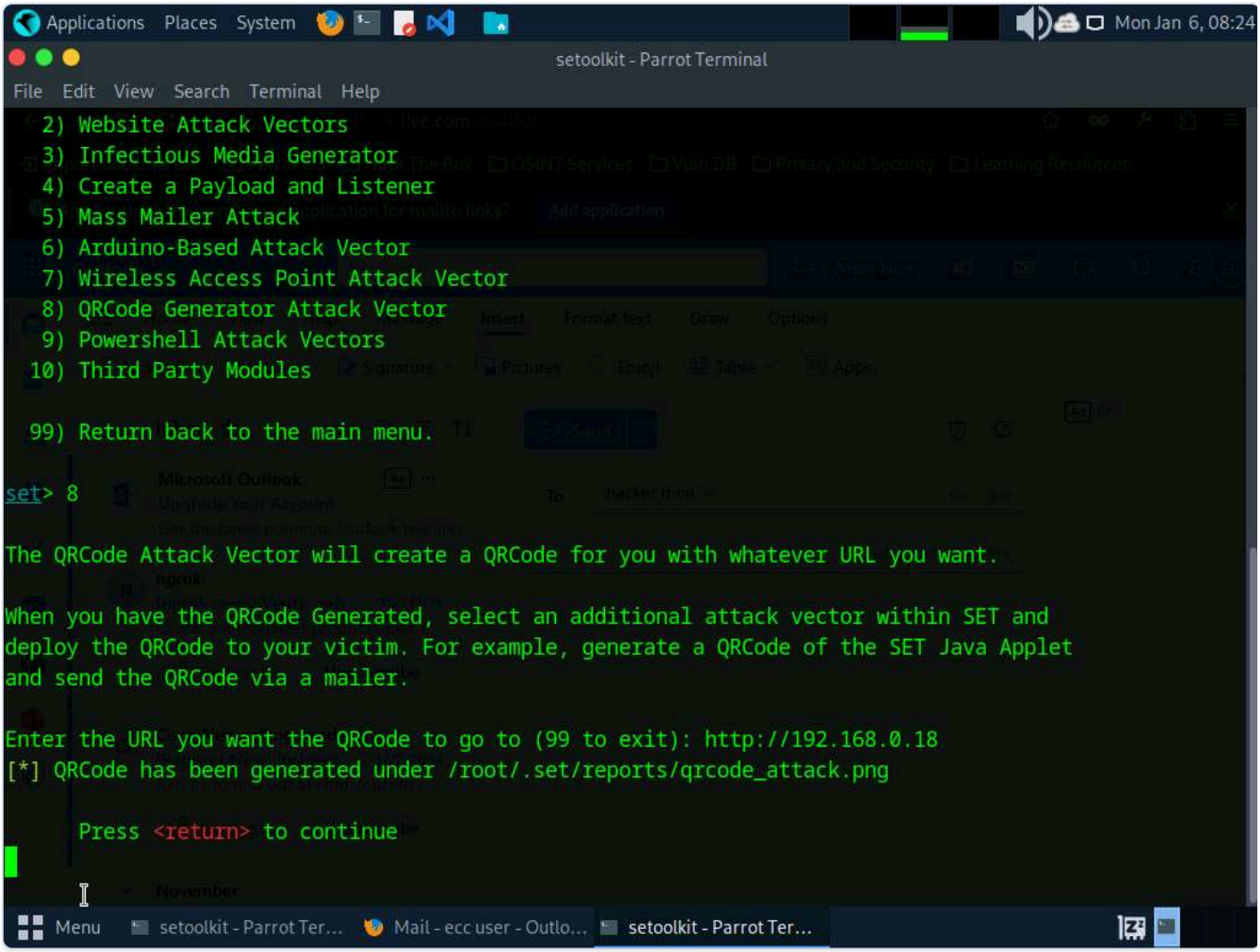
1. A list of options for Social-Engineering Attacks appears; type **8** and press Enter to choose **QRCode Generator Attack Vector**.



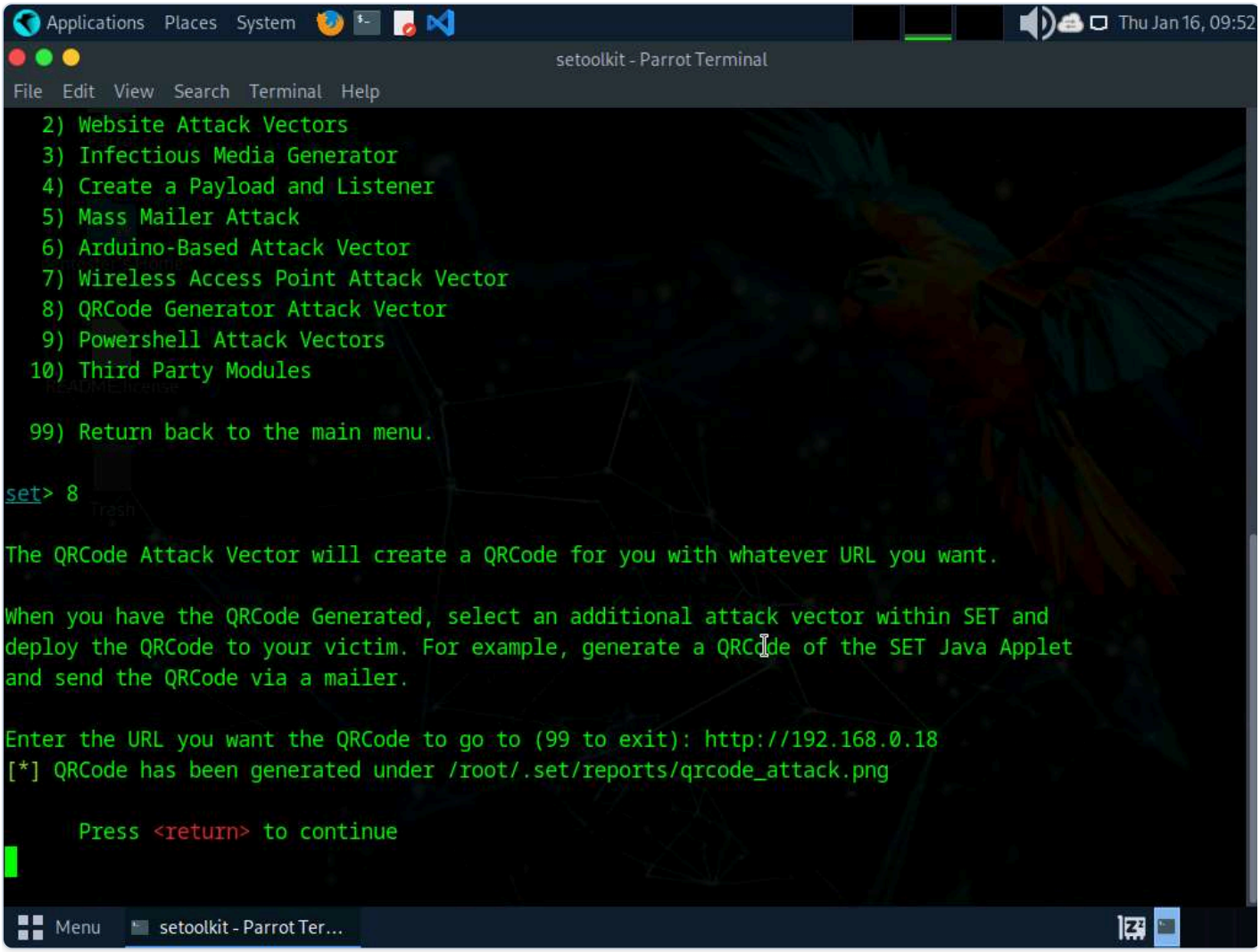
1. You need to enter the URL you want the QR code to map to. In this scenario, it is **http://192.168.0.18**. Type it and press Enter.



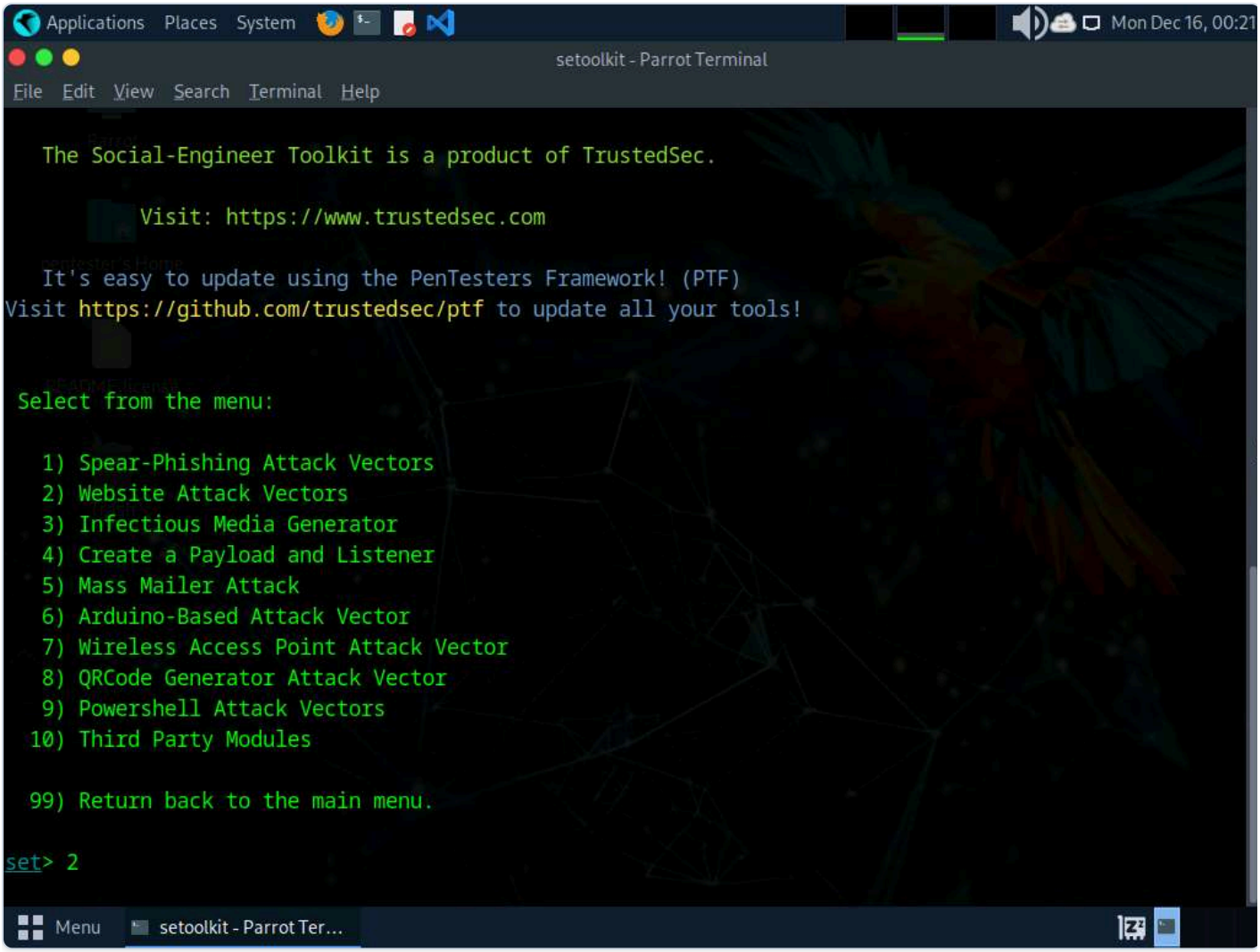
1. The QR code is generated with the URL and saved to **CPENTv2 Pen Testing Resources/SET Reports** by default, with the name **qrcode_attack.png**.



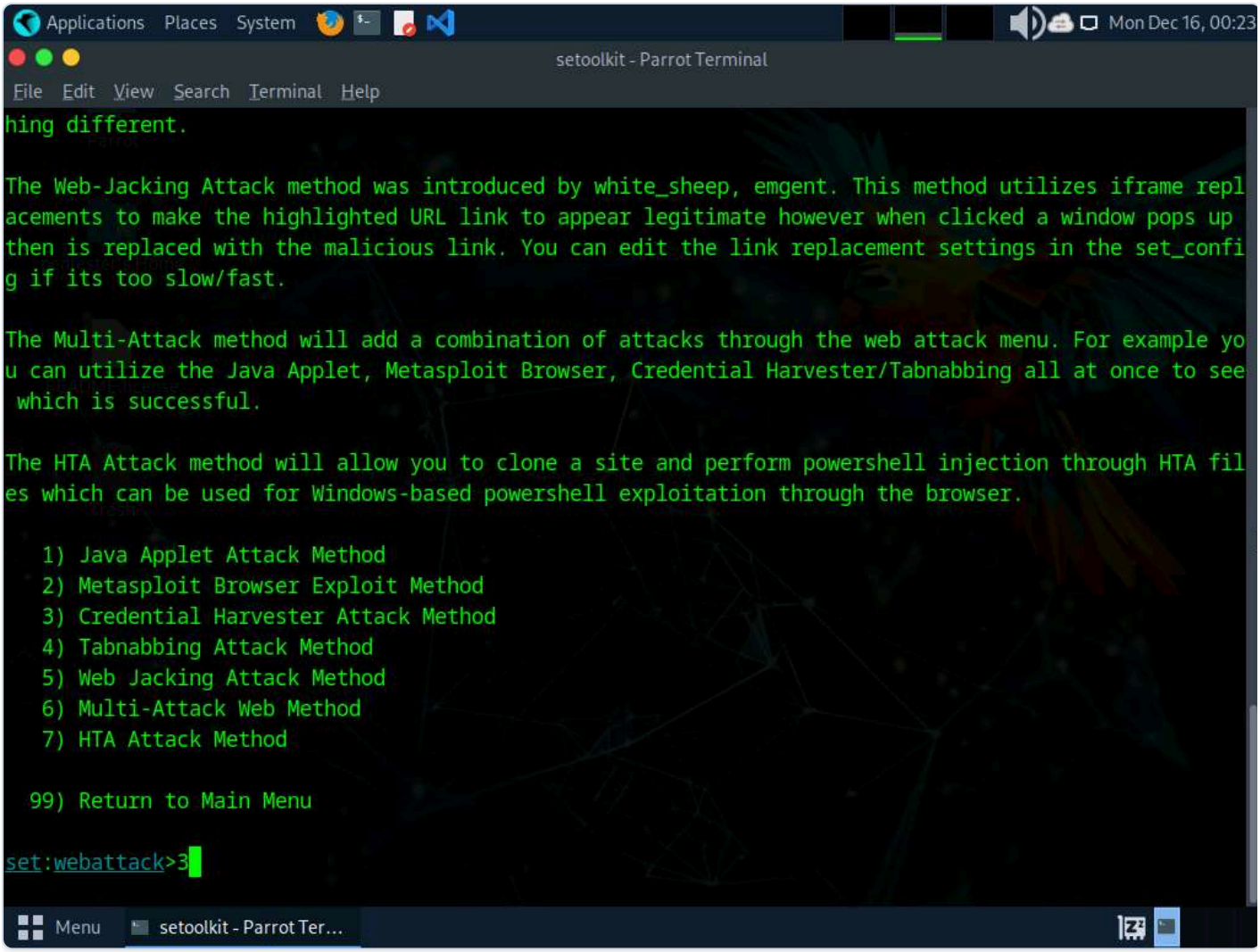
1. If a message appears that says *"Press to continue"*, press Enter.



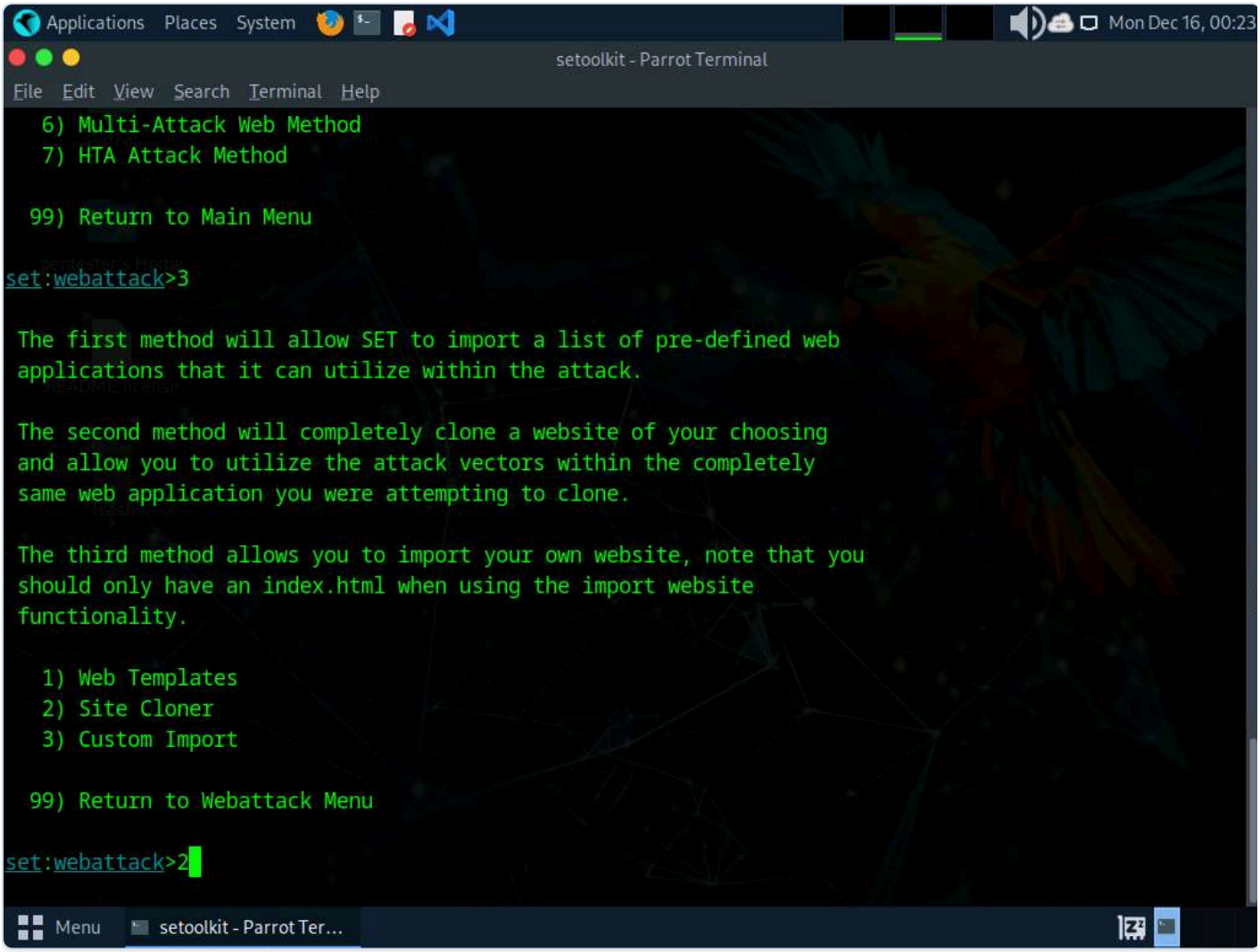
1. A list of options for Social-Engineering Attacks appears; type **2** and press Enter to choose **Website Attack Vectors**.



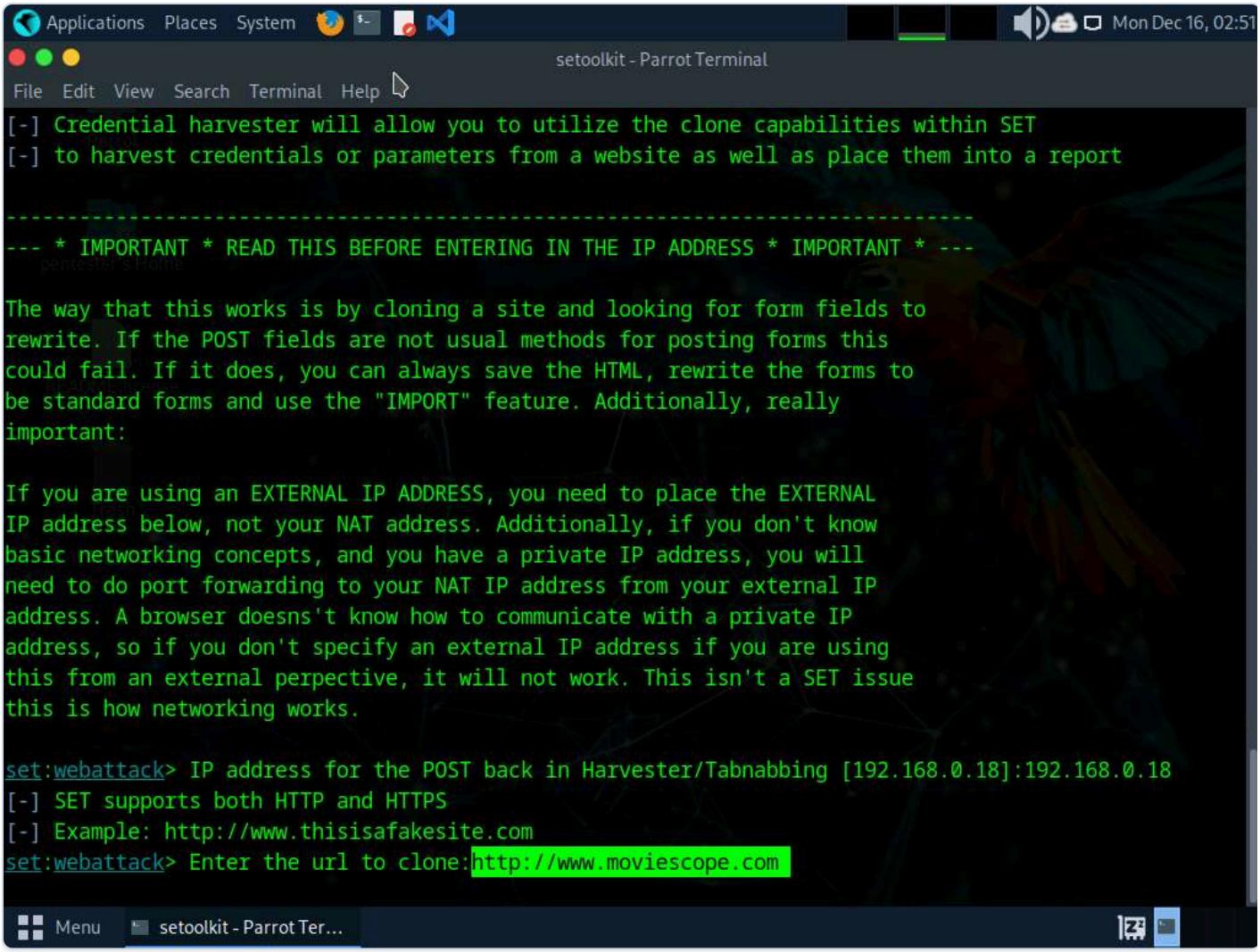
1. A list of options in Website Attack Vectors appears; type **3** and press Enter to choose **Credential Harvester Attack Method**.



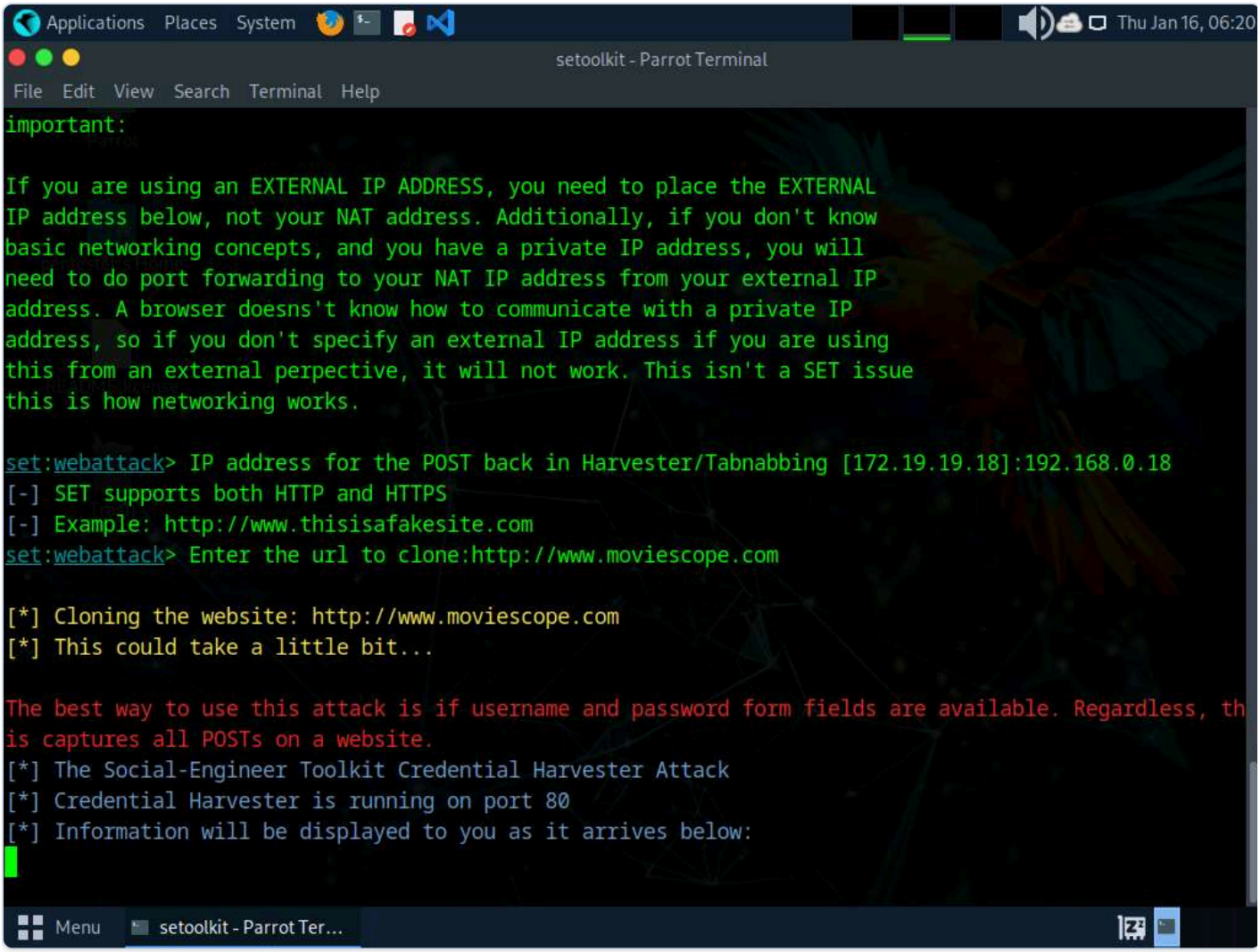
1. Type **2** and press Enter to choose **Site Cloner** from the menu.



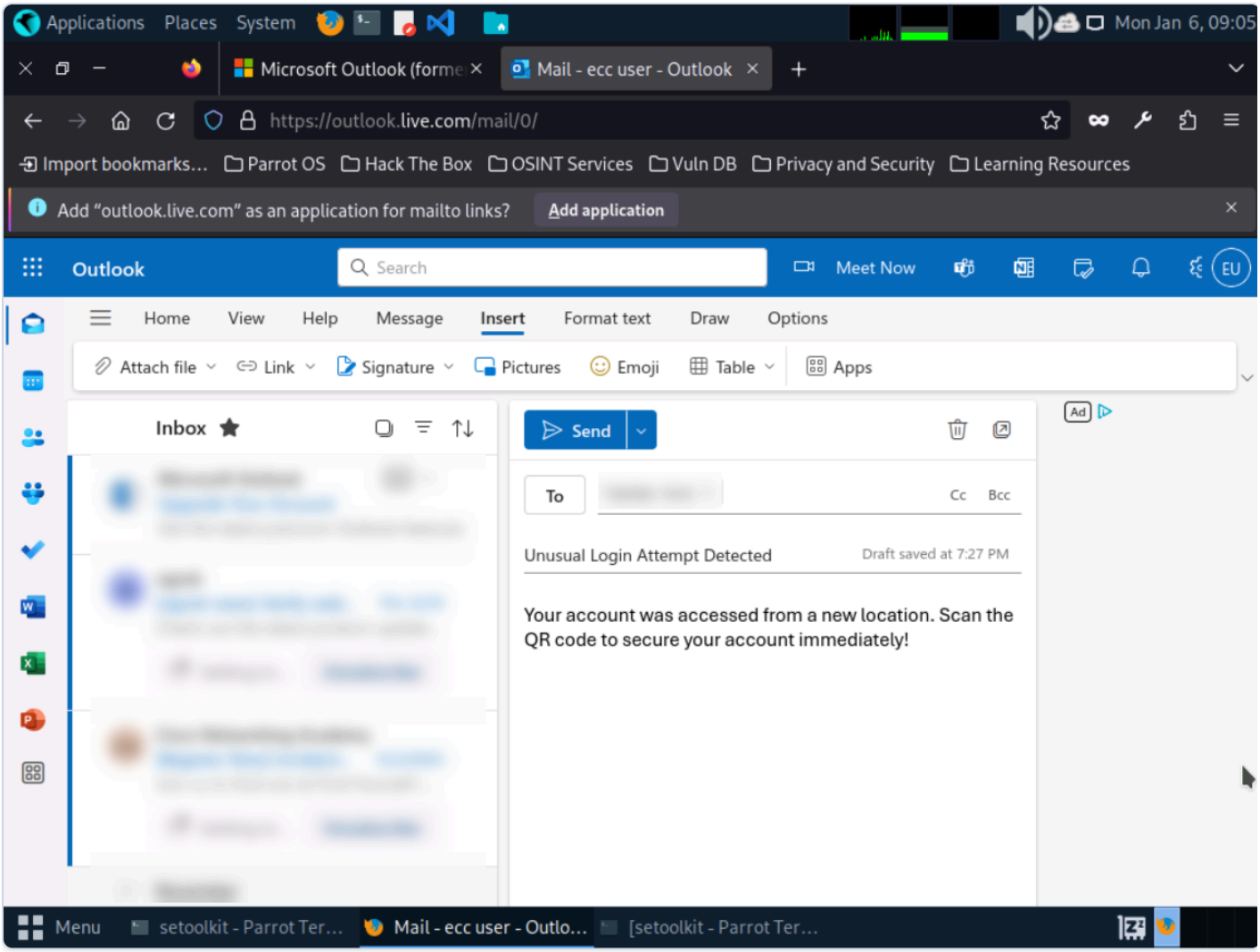
1. Type the IP address of the local machine (**192.168.0.18**) in the prompt for *"IP address for the POST back in Harvester/Tabnabbing"* and press Enter.
   - *(In this case, we are targeting the Parrot Security machine (IP address: **192.168.0.18**).)*
2. Now, you will be prompted for the URL to be cloned; type the desired URL in the *"Enter the url to clone"* field and press Enter. In this task, we will clone the URL **http://www.moviescope.com**.



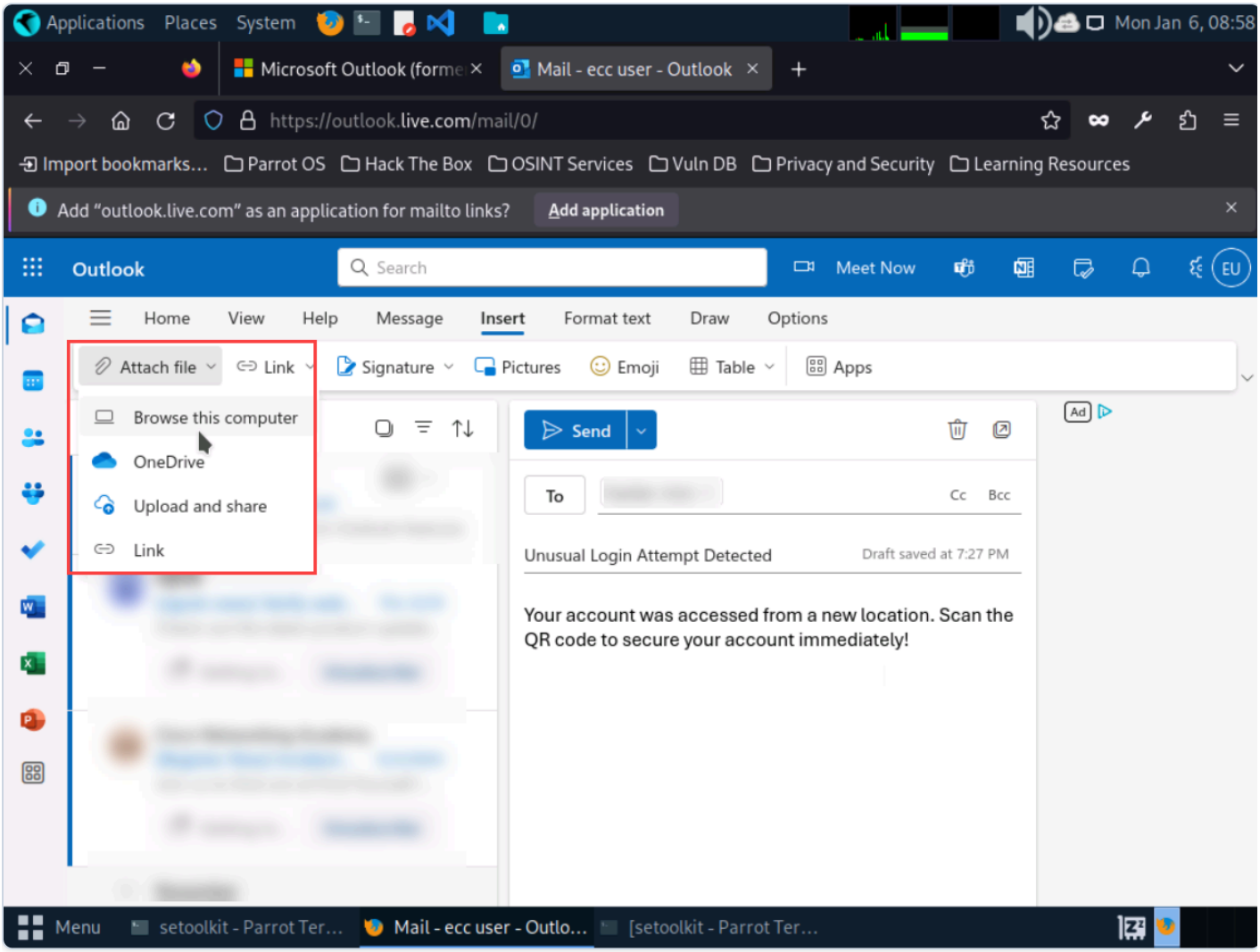
1. Once the cloning is complete, the Credential Harvester will be initiated, as shown in the screenshot below.



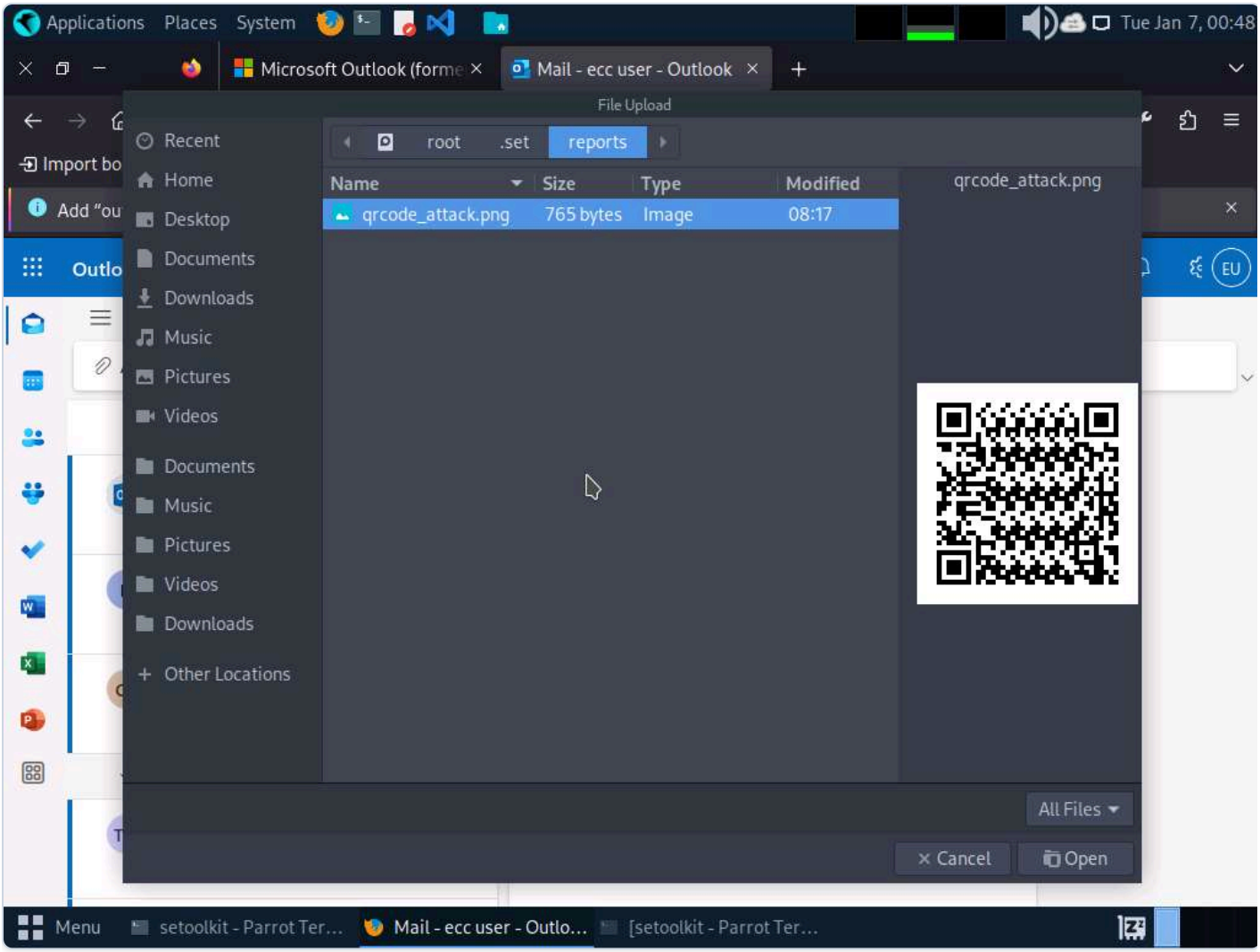
1. Having successfully created a QR code and a cloned page, you must now send this to a victim and try to trick them into scanning the QR code and accessing the link beneath it. We will be using email as a medium to send the QR code.
2. Assuming you are logged in to your email account (in continuation to the previous section), click the **New Mail** button in the left pane and compose a fake but enticing email.



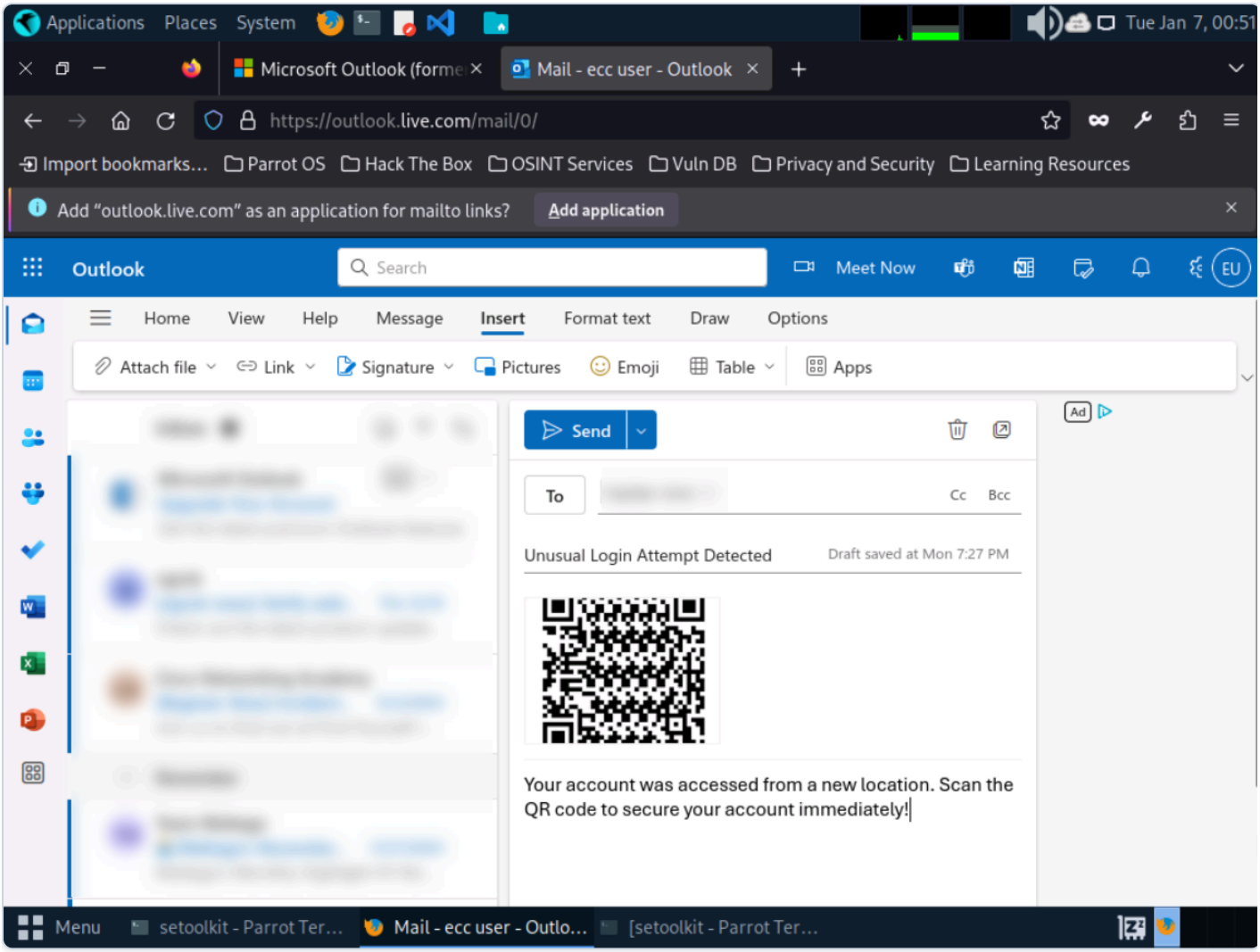
1. Upon composition, attach the QR code to the email by clicking **Attach file** → **Browse this computer**.



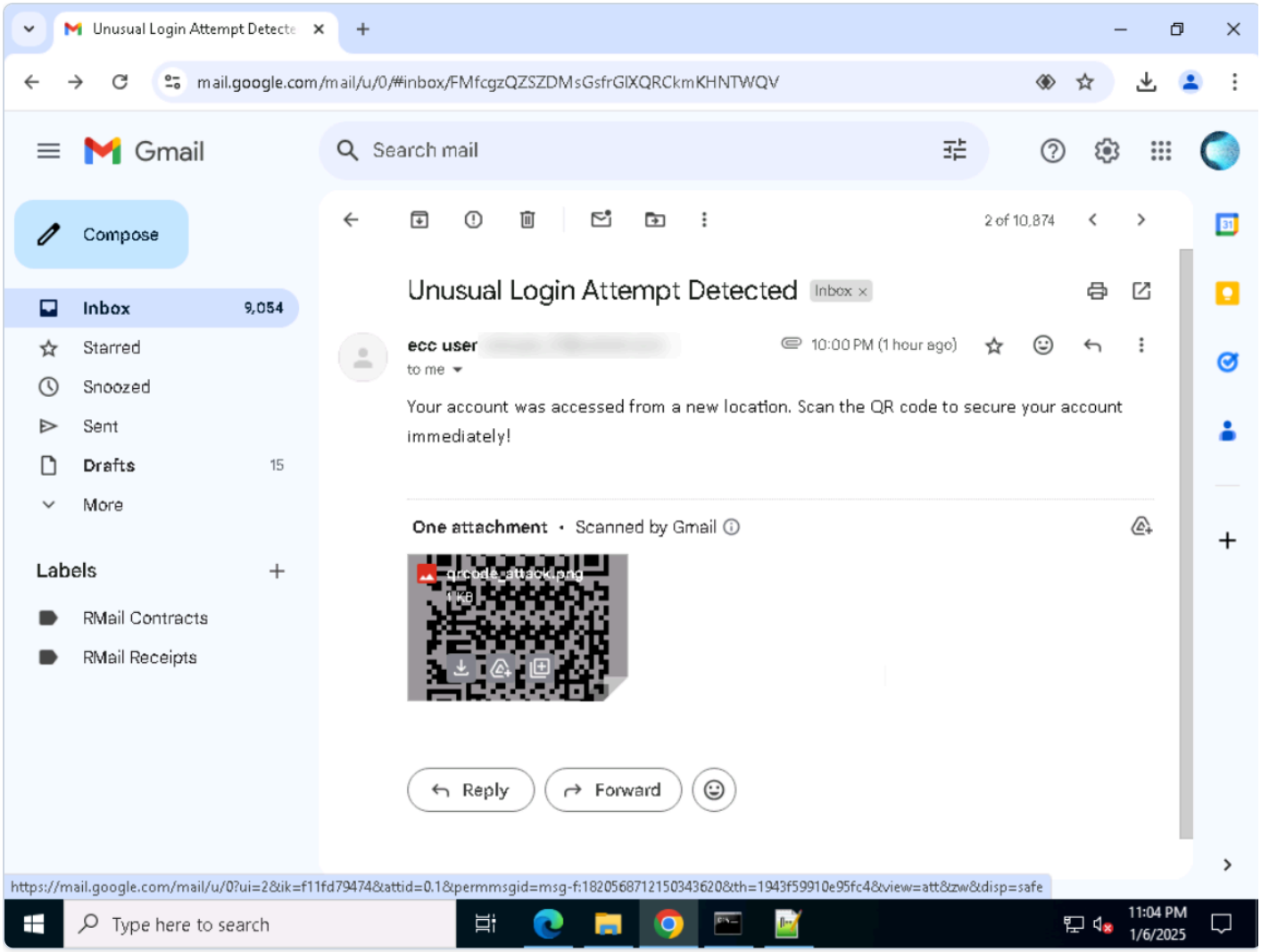
1. File Upload window appears, navigate to **CPENTv2 Pen Testing Resources/SET Reports**, select **qrcode_attack.jpg** and click **Open**.
   - *(If the .set folder is not found, right-click and click on the Show Hidden Files option to see the folder.)*



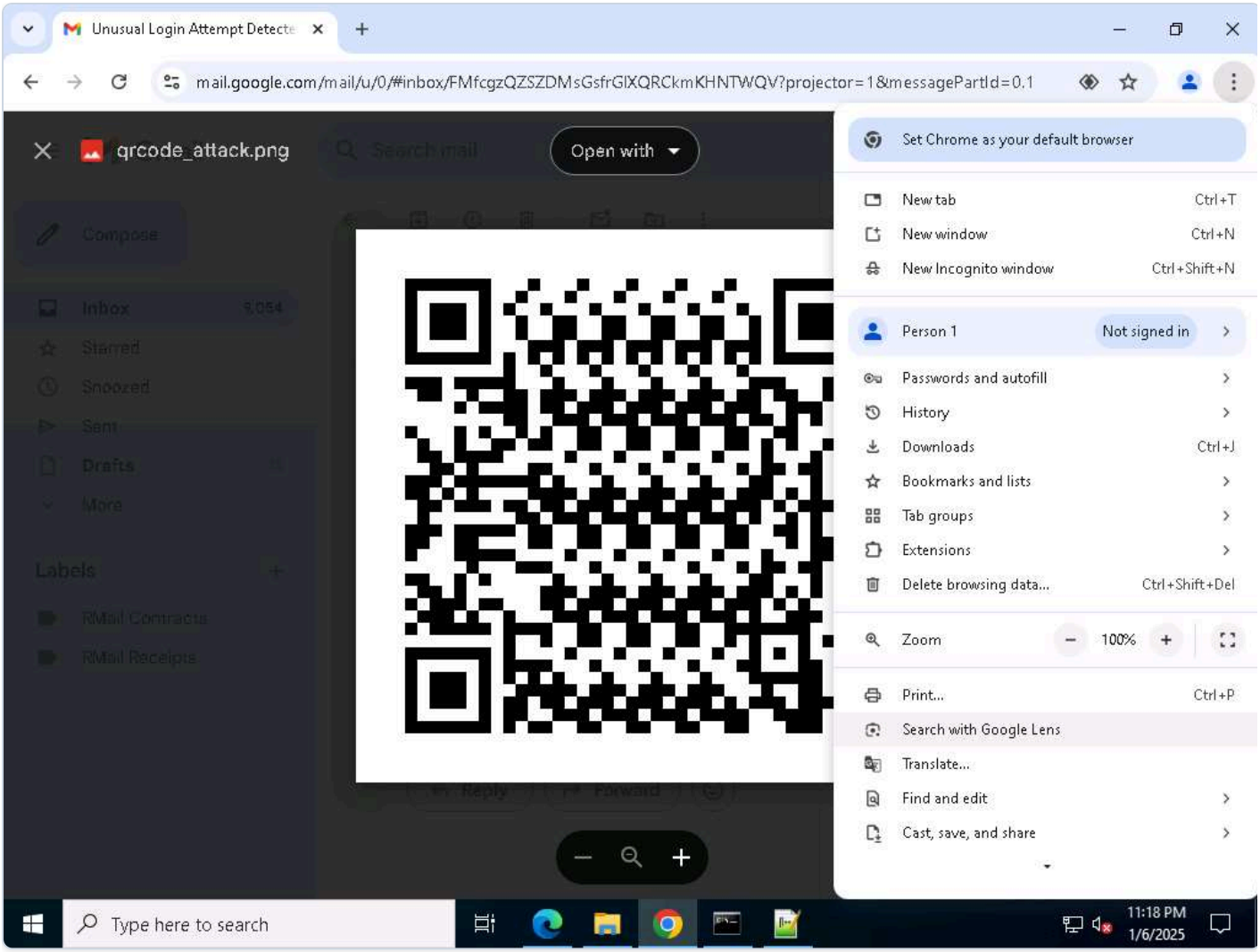
1. The QR code is now appended to the email. You can now send it to the intended recipient.



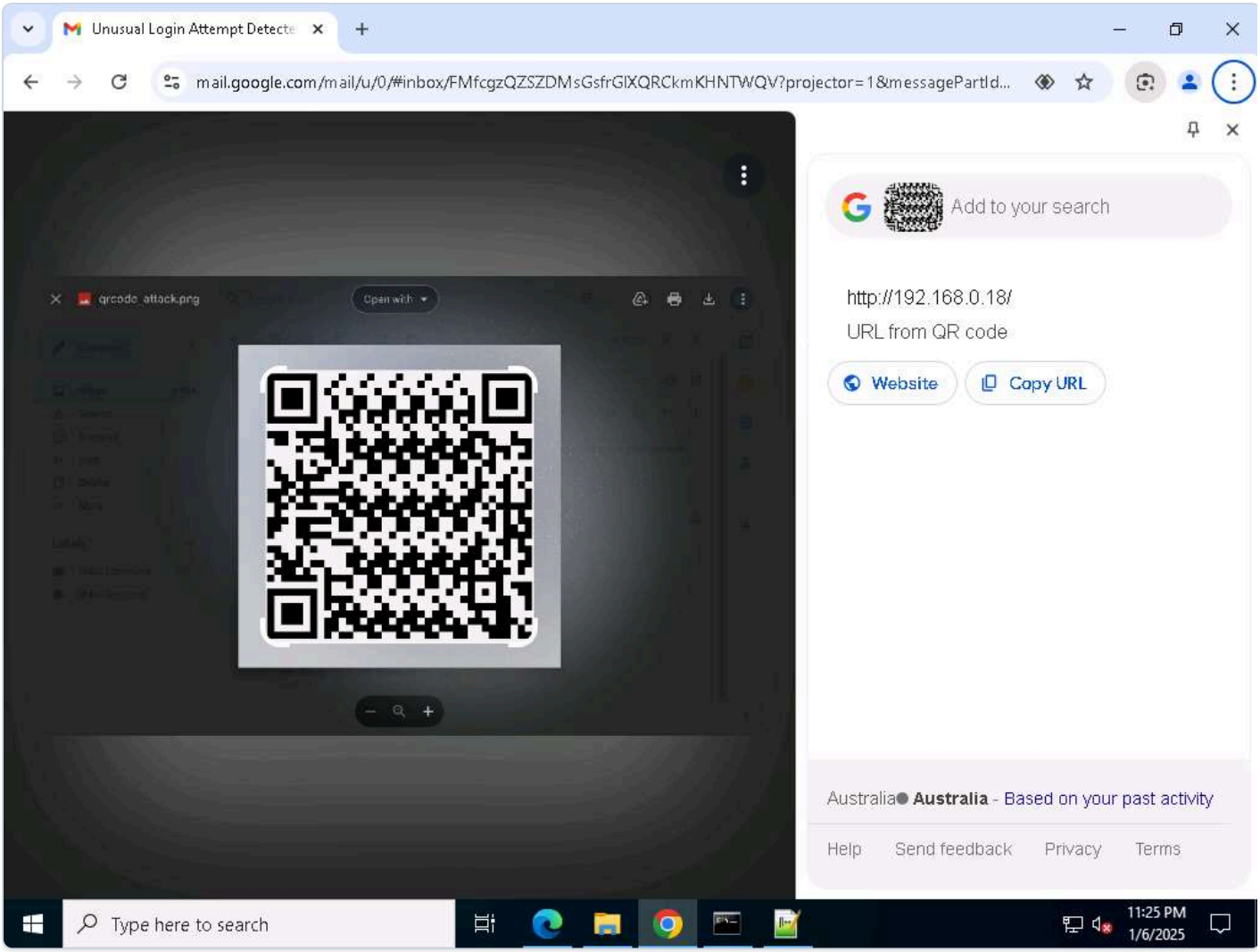
1. Click **Windows Server 2022** to switch to the Windows machine you accessed in the previous section.
2. Open Google Chrome and access the email account to which you sent the phishing mail as an attacker. Open the email you sent previously and click on the QR Code.



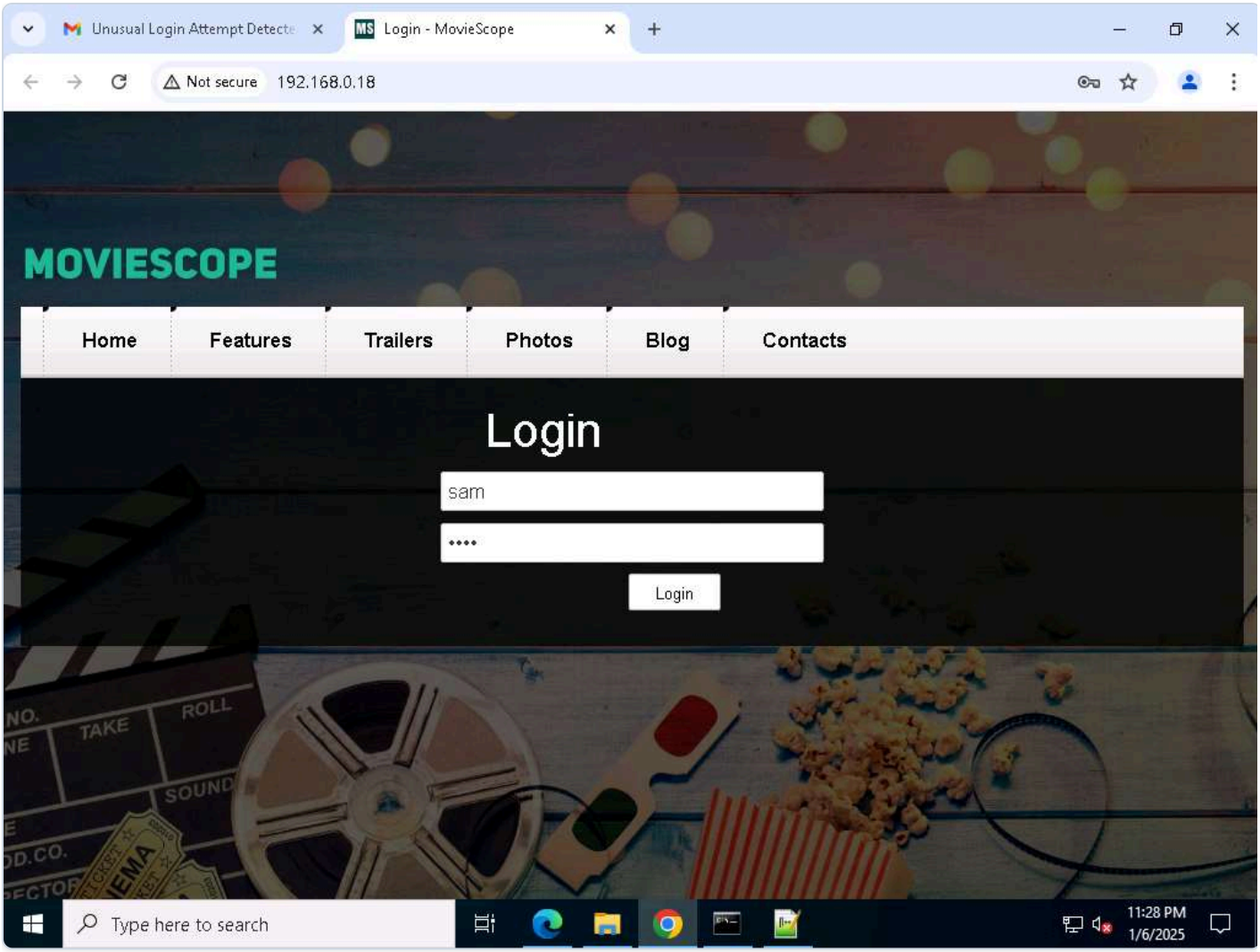
1. In real-time, the user may scan the QR code from their mobile or use Google Lens (via Chrome browser) from their machine. In this lab, we will be scanning the code using Google Lens. To scan, click the Ellipsis icon present at the top-right corner of the browser window and select **Search with Google Lens**.

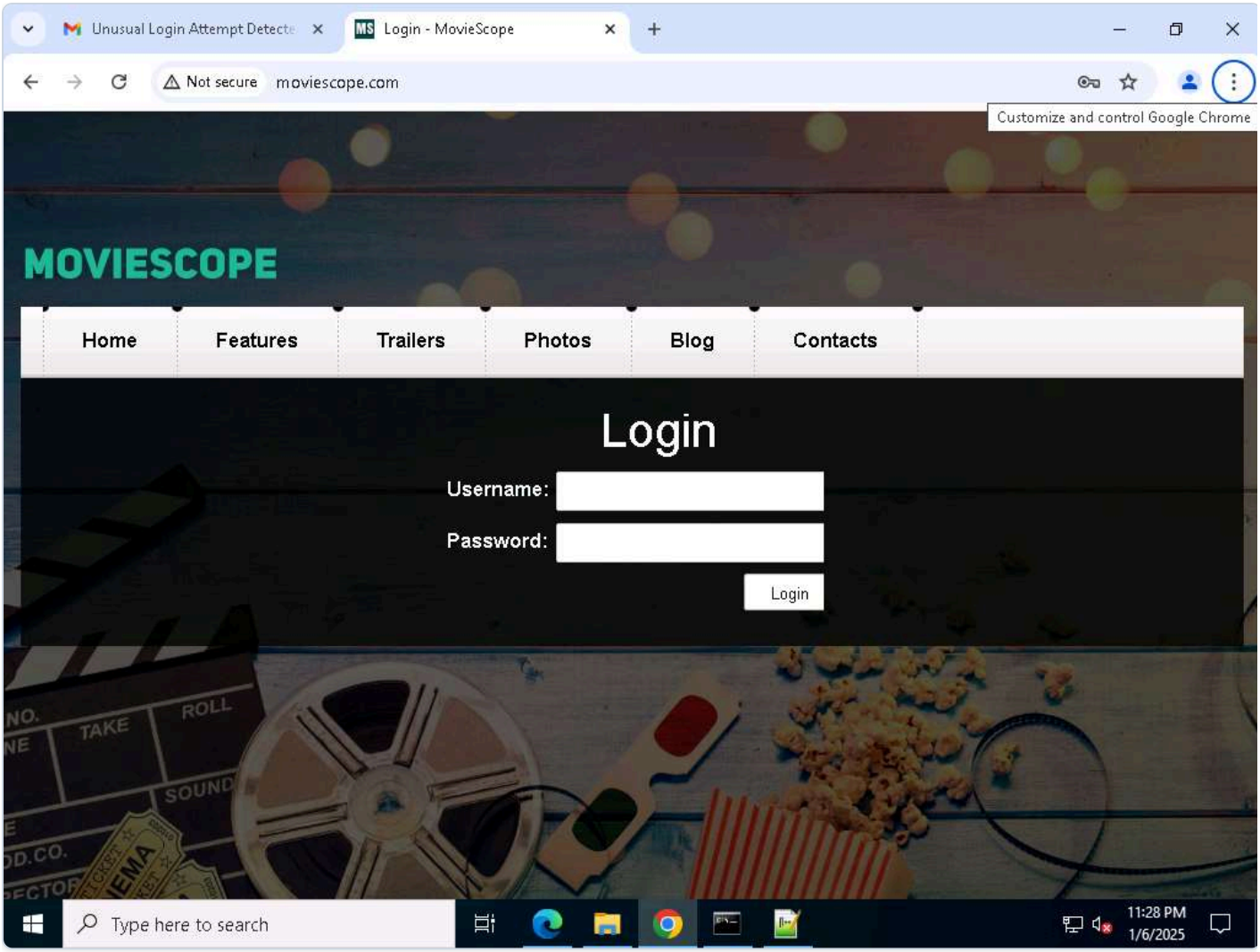


1. Hover the mouse cursor over the QR code and click on top of the code. You will be presented with two options on the right pane - Website and Copy URL. Click **Website**.

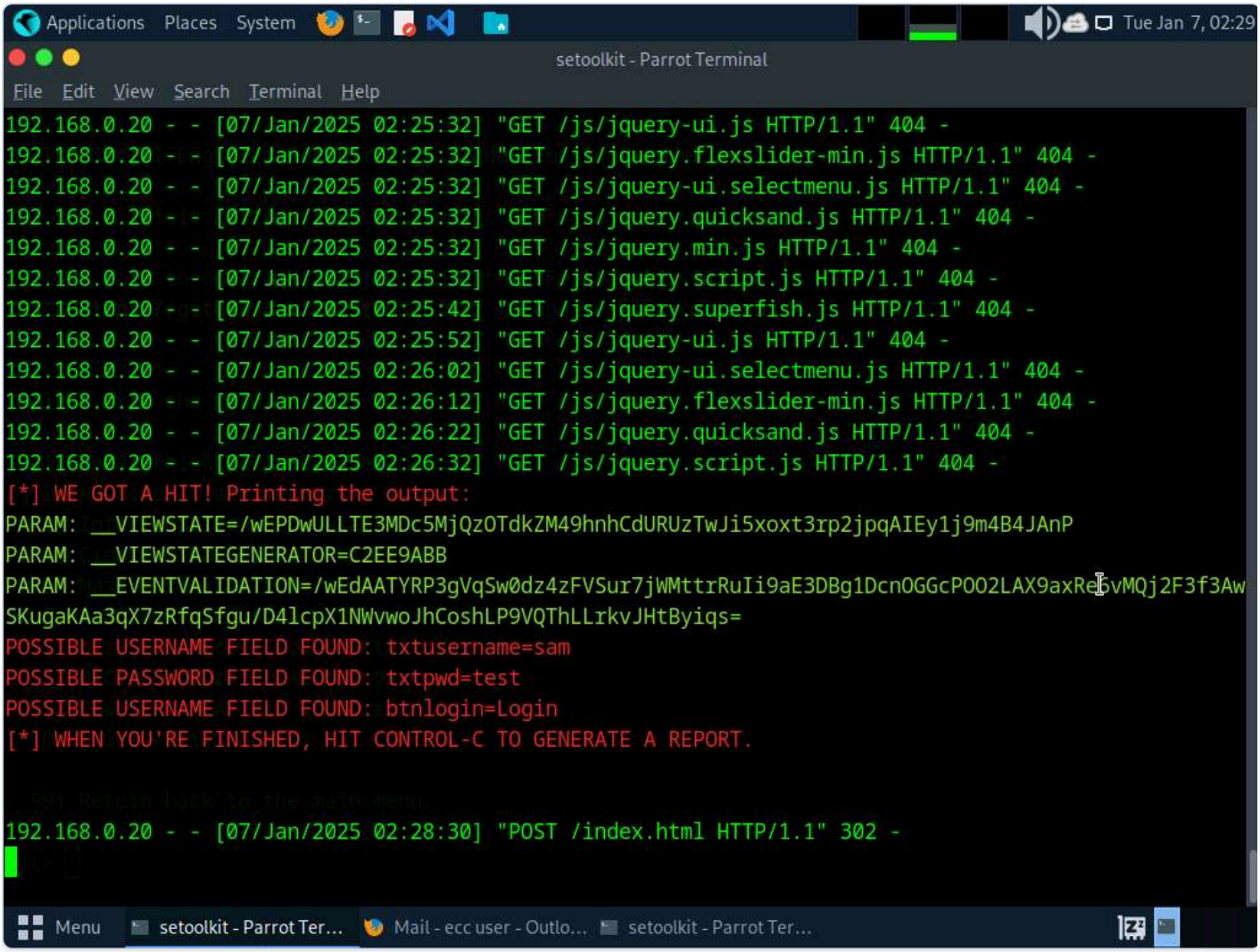


1. When the victim (you, in this case) clicks Website, a new tab opens up, and they will be presented with a replica of **www.moviescope.com**.
2. The victim will be prompted to enter the username and password into the form fields, which appear as they do on the genuine website. When the victim enters the Username and Password and clicks Login, they will be redirected to the legitimate MovieScope login page. Note the different URLs in the browser address bar for the cloned and legitimate sites.


Unusual Login Attempt Detecte
Login - MovieScope
Not secure
192.168.0.18
MOVIESCOPE
Home
Features
Trailers
Photos
Blog
Contacts
Login
sam
Login
Type here to search
11:28 PM
1/6/2025



1. Now, click **Parrot Security** to switch back to the Parrot Security machine and then, switch to the terminal window. Once the victim enters their Username and Password and clicks Login, SET captures these credentials.
2. Scroll down to find the Username and Password displayed in plain text, as shown in the screenshot.



This concludes the demonstration of phishing user credentials using the SET. Close all open windows and document all the acquired information.

> **IMPORTANT:** ❓ **Question 4.1.2.1** On the Parrot Security machine, utilize the Social Engineering Toolkit (SET) to capture user credentials by employing the Site Cloner and QR Code Generator Attack Vector. Use the default name assigned to the generated QR code. [!SUCCESS] ✅ **Answer:** **qrcode_attack.png**